

制造中台 (PLS)

应用安全检测报告

认证态 + 未认证黑盒 (经隧道直连, 最小影响测试)

委托单位: 东风商用车有限公司

测试人员: AI 安全员

测试日期: 2026 年 07 月 30 日

安全测试组

检测概述

背景介绍

随着国内外网络安全形势日益严峻，攻防不对等拉锯，网络攻击入侵门槛不断拉低，同时网络安全法的落地实施，国家监管层面不断加大信息系统安全监管及处罚力度。一旦信息系统应用软件存在安全漏洞、配置不规范或业务安全风险，易遭受到网络安全攻击，给应用系统的稳定运行、数据安全带来了极大的风险隐患，信息系统的安全已经成为了目前迫切亟待解决的问题。

为进一步加强网络安全管理与数据安全保护，切实防范信息安全风险，依据国家（行业）标准和监管合规要求，对目标系统 <http://10.124.10.249/>（内网）开展应用安全检测，全面识别应用系统面临的安全风险隐患，包含业务安全风险，及时采取相应的技术措施进行安全防范和修复加固，降低攻击入侵，提升业务系统安全健壮性，保障业务系统安全运行。

参考标准

此检测报告引用以下标准与规范（版本于报告编制时经官方来源核对，均为现行有效版本，并结合被测对象所属行业选取相关项）：

- 《OWASP Web Security Testing Guide v4.2》
- 《OWASP Top 10:2025》
- 《PTES 渗透测试执行标准》
- 《ISO/IEC 27001:2022 信息安全管理体糸》
- 《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
- 《GB/T 30279-2020 信息安全技术 网络安全漏洞分类分级指南》
- 《GB/T 30276-2020 信息安全技术 网络安全漏洞管理规范》
- 《GB/T 40856-2021 车载信息交互系统信息安全技术要求及试验方法》
- 《汽车数据安全若干规定（试行）》
- 《UN R155 关于汽车网络安全的统一规定》
- 《UN R156 关于汽车软件升级的统一规定》
- 《中华人民共和国网络安全法》（2025 修正，2026-01-01 施行）
- 《中华人民共和国数据安全法》
- 《中华人民共和国个人信息保护法》

注：上述标准每次执行检测前应重新核对是否有更新版本。

适用说明

针对软件应用（含移动服务端、C/S 服务端等）开展应用安全检测，本次被测对象为 制造中台（PLS），不涉及主机、配置等其他检测。

工作原则

开展安全检测应遵循的工作原则是：

(1) 规范性原则

安全检测过程有统一的流程，安全检测中使用的方法及使用的文档，需要具有很好的规范性，便于安全检测工作的质量保证，并保证结果的一致性。

(2) 可控性原则

安全检测所使用的工具、方法和过程要在双方认可的范围之内，安全检测的进度要符合进度表的安排，保证双方对安全检测的可控性。

(3) 整体性原则

安全检测的范围和内容应当系统性、全面，覆盖信息系统安全所涉及的各个层面，并考虑各个层面的相互关系。

(4) 最小影响原则

安全检测应尽可能较小的影响网络和系统的正常运行，不能对系统的业务产生显著影响，避免造成被测评系统的性能明显下降、网络拥塞、服务中断等；不删除或修改数据、不触发破坏性操作、不进行高强度爆破、不执行破坏性注入类测试。

(5) 保密性原则

对在安全检测中所接触到的用户单位的所有敏感信息，检测人员应遵循相关的保密承诺，不利用相关信息进行任何侵害被检测单位安全利益的行为。本报告不含口令、完整 Cookie、令牌等敏感原文。

检测内容

该检测报告用于应用系统安全检测，可覆盖已上线前安全检测、上线后安全检测、安全评估、互联网安全检测等场景，包含端口安全、基线安全、前端安全、传输安全、身份鉴别、权限管理、会话安全、密钥安全、异常处理、业务安全、日志审计、数据安全、常见漏洞等 13 个大类，共计 55 项安全检测内容。

检测工具

安全检测工具清单如下（当前列举为本次实际使用的主要工具，结合不同应用类型和漏洞组件验证，会使用到其他检测工具）：

工具名称	工具类型	工具用途
浏览器 + 开发者工具	手工检测	页面/JS/Cookie/请求响应观察取证

curl	手工检测	HTTP 请求构造与响应验证
Python (http.client)	自动化脚本	批量接口探测、权限对比、注入测试

检测声明

安全检测在应用系统上线前开展，如测试环境和生产环境一致，宜使用测试环境开展，如测试和生产差异较大，两套环境应同时开展检测，检测前应确保应用所有组件部署完成，并提供生产和测试环境所有资产信息。

本报告为本次应用安全检测服务的输出结果，供业务方进行漏洞修补和安全加固参考，并进行安全风险规避，安全控制和管理。

本报告的检测结论仅对被测对象当时的状态有效。当检测完成后，由于被测对象的系统变更，本报告不再适用。

在任何情况下，若需引用本报告中的结果或结论都应保持其原有的意义，不得对相关内容擅自进行增加、修改和伪造或掩盖事实。

变更记录

时间	版本	说明	修改人
2026-07-30	V1.0	创建应用安全检测报告（认证态+未认证黑盒，经隧道直连）	AI 安全员

检测结果

检测信息

项目名称	系统级别	应用网址	IP 地址
制造中台（PLS）	等保三级	http://10.124.10.249/（内网）	10.124.10.249（内网，脱敏）

风险信息

本次安全检测共完成 55 项检测内容，共计发现 23 个安全风险，其中高危风险 2 个、中危风险 21 个、低危风险 0 个（判定为“不符合”）。另有“符合” 30 项、“未测试” 0 项、“不涉及” 2 项。

“未测试” 0 项系因测试条件受限（如缺少对照账号、生产环境非破坏性约束、经隧道无法验证等）无法完成验证，据实标记并说明原因；“不涉及” 2 项系统不涉及对应功能场景。

风险汇总

序号	风险章节	风险名称	风险等级	复测结果
1	3.2.1	应用软件及相关组件版本基线安全测试	中	
2	3.3.1	前端 JS 库软件版本安全测试	中	
3	3.4.1	软件版本信息泄漏安全测试	中	
4	3.4.2	防重放攻击、防篡改功能安全测试	中	
5	3.5.1	验证码功能安全测试	中	
6	3.5.3	双因素验证功能安全测试	中	
7	3.5.4	首次登录强制改密安全测试	中	
8	3.5.5	身份验证失败处理安全测试	中	
9	3.5.9	长期不登录账号锁定安全测试	中	
10	3.6.2	防越权安全测试	高	
11	3.7.1	Cookie 安全测试	中	
12	3.7.4	会话超时安全测试	中	
13	3.8.1	密钥存储安全测试	中	
14	3.10.4	重要数据类型验证安全测试	中	
15	3.11.1	基础日志审计功能安全测试	中	
16	3.12.1	加密传输安全测试	中	
17	3.12.2	数据脱敏展示安全测试	中	
18	3.12.3	数据导出安全测试	中	
19	3.13.1	HTTPS 协议安全测试	中	
20	3.13.14	开发框架、中间	中	

		件安全测试		
21	3. 13. 15	未授权访问安全测试	高	
22	3. 13. 16	敏感信息泄露安全测试	中	
23	3. 13. 17	处理用时安全测试	中	

注：上表仅列出本次判定为“不符合”的 23 项风险；全部 55 项检测内容的逐项结果（含符合/未测试/不涉及）详见“检测详情”。“复测结果”列供整改复测时填写。

检测详情

端口安全

应用端口服务安全测试

测试编号	PORT-001
风险名称	应用端口服务安全测试
风险等级	中
功能要求	排查应用高危端口可直接访问等风险，如排查应用或服务管理端（包含不限于网络安全设备、云平台、虚拟化平台、大数据平台、邮件管理端、通用类应用管理端等）端口是否限制直接访问、tomcat ajp 协议是否做隔离等风险。 对于三级系统以及重要业务系统，如车联网系统、营销系统等，要求业务端和管理端进行端口分离。 3、对于三级系统以及重要业务系统，如车联网系统、营销系统等，管理端端口应进行 IP/IP 段（范围不易过大）白名单访问限制。
风险影响	攻击者通过高危端口对应用服务开展漏洞利用攻击行为，获取应用服务权限并造成敏感信息泄露
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	符合
截图说明	经隧道对 80 端口逐一探测常见管理/监控入口：/nginx_status、/server-status、/console、/manager、/jmx-console、/jolokia、/prometheus、/metrics、/server-api/actuator/*（health/env/metrics/prometheus）等均返回 404 或 SPA 兜底页，未发现暴露的中间件管理端、监控端或未授权管理接口。对外仅通过 80 端口提供业务应用（nginx 反代 SPA + /server-api 后端）。
修复建议	
备注	隧道仅映射 80 端口，未做主机全端口扫描；如需完整端口面基线建议内网侧补充 Nmap 全端口扫描。

```
HTTP 请求 & 响应 (GET /)

# Response Headers
Server: nginx/1.21.5
Content-Type: text/html
Cache-Control: public, max-age=86400
X-Frame-Options: (absent)
X-Content-Type-Options: (absent)
Content-Security-Policy: (absent)
Strict-Transport-Security: (absent)

# HTTP Methods (on /)
OPTIONS: 405 | TRACE: 405 | PUT: 405 | DELETE: 405 | PATCH: 405
[+] 检测 HTTP 漏洞扫描

# Frontpage Fingerprint
<title>测试</title> | SPA (Vue + ElementUI + webpack)
assets: chunk-elementUI.*.js, chunk-lib.*.js, app.*.js

# Swagger/API-docs (unauthenticated)
/server-api/webjars/swagger-ui/index.html -> 200 (Swagger UI page)
/server-api/v3/api-docs -> 200 (OpenAPI JSON, paths:{})
servers[0].url = http://[INTERNAL_IP] <-- info leak

[!] 检测 (XFO/XCTO/CSP/HSTS)
[!] Server 检测: nginx/1.21.5 (2021-Dec, known CVEs)
[!] 检测 HTTP 与 HTTPS - 检测
```

图：管理/监控端口未暴露，仅 80 端口提供业务

基线安全

应用软件及相关组件版本基线安全测试

测试编号	BASIC-001
风险名称	应用软件及相关组件版本基线安全测试
风险等级	中
功能要求	应用软件开发框架、中间件和其他应用组件等，应满足安全基线要求
风险影响	低版本组件存在安全漏洞，攻击者利用漏洞可获取敏感信息或服务器应用权限
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	不符合
截图说明	响应头暴露 Server: nginx/1.21.5（2021 年 12 月发布），已有多个已知 CVE（CVE-2022-41741/41742 等）。后端为 Spring Boot 应用（Swagger/springdoc 在线），具体框架版本未直接暴露但中间件版本过旧。
修复建议	升级 nginx 至最新稳定版（≥1.25.x）；定期审查并升级后端框架与依赖组件。
备注	

```
HTTP 请求 & 响应 (GET /)

# Response Headers
Server: nginx/1.21.5
Content-Type: text/html
Cache-Control: public, max-age=86400
X-Frame-Options: (absent)
X-Content-Type-Options: (absent)
Content-Security-Policy: (absent)
Strict-Transport-Security: (absent)

# HTTP Methods (on /)
OPTIONS: 405 | TRACE: 405 | PUT: 405 | DELETE: 405 | PATCH: 405
[+] 检测 HTTP 漏洞扫描

# Frontpage Fingerprint
<title>测试</title> | SPA (Vue + ElementUI + webpack)
assets: chunk-elementUI.*.js, chunk-lib.*.js, app.*.js

# Swagger/API-docs (unauthenticated)
/server-api/webjars/swagger-ui/index.html -> 200 (Swagger UI page)
/server-api/v3/api-docs -> 200 (OpenAPI JSON, paths:{})
servers[0].url = http://[INTERNAL_IP] <-- info leak

[!] 检测 (XFO/XCTO/CSP/HSTS)
[!] Server 检测: nginx/1.21.5 (2021-Dec, known CVEs)
[!] 检测 HTTP 与 HTTPS - 检测
```

图：Server 头暴露 nginx/1.21.5

前端安全

前端 JS 库软件版本安全测试

测试编号	FRON-001
风险名称	前端 JS 库软件版本安全测试
风险等级	中
功能要求	前端应使用满足基线版本的 JavaScript 库版本
风险影响	低版本的 JavaScript 库存在已知安全漏洞，这些漏洞可能允许攻击者在用户浏览网页时执行恶意操作，如窃取用户数据、操纵页面内容、发起跨站脚本攻击 (XSS)、执行服务器端请求伪造 (SSRF)、进行点击劫持或其他形式的攻击手段
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	不符合
截图说明	分析前端 chunk-lib.js (594KB) 提取到过旧的第三方库版本：1) Vue.js 2.6.12 ((c)2014-2020, Vue 2.x 已于 2023-12-31 停止维护，处于 EOL)；2) lodash 3.0.0pre (远低于安全版本 4.17.21, 3.x/低版本存在原型污染 CVE-2019-10744 等)；3) axios 0.24.0 (偏旧，存在 CVE-2023-45857 等)。均不满足前端组件安全基线。
修复建议	升级前端依赖至受支持的安全版本：Vue 升至 2.7.x 最新补丁或迁移 Vue 3；lodash 升至 4.17.21+；axios 升至 1.x 最新版；建立 SCA (如 retire.js/Snyk/Dependabot) 持续监控。

备注	<pre>## JS 依赖 (FRON-001, chunk-libs.js) # @ chunk-libs.188f53d4.js (594KB) 依赖 Vue.js 2.6.12 (c) 2014-2020 Evan You [!] Vue 2.x 2023-12-31 过期 (EOL) lodash 3.0.0pre (Custom Build) [!] lodash 3.x 过期 (CVE-2019-10744), 版本 4.17.21 axios 0.24.0 [!] axios 0.24 版本 (CVE-2023-45857 SSRF 漏洞, 版本 1.x) [!] 依赖过期, 依赖过期, 依赖过期</pre>
----	--

图：Vue 2.6.12(EOL) / lodash 3.0 / axios 0.24 版本过旧

前端 JS 泄露安全测试

测试编号	FRON-002
风险名称	前端 JS 泄露安全测试
风险等级	中
功能要求	前端 JS 文件应不包含敏感信息，如接口、密钥、个人敏感信息、应用敏感信息等
风险影响	前端 JS 文件中的存在敏感信息可能被攻击者探测获取，造成敏感信息泄露。
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	符合
截图说明	审查前端 app.js (461KB)：仅含 baseUrl:“/server-api”等常规配置，未发现硬编码密钥、Token、AK/SK、个人信息或内部 IP/域名等敏感信息。
修复建议	
备注	

```
HTTP 请求 & 响应 (GET /)

# Response Headers
Server: nginx/1.21.5
Content-Type: text/html
Cache-Control: public, max-age=86400
X-Frame-Options: (absent)
X-Content-Type-Options: (absent)
Content-Security-Policy: (absent)
Strict-Transport-Security: (absent)

# HTTP Methods (on /)
OPTIONS: 405 | TRACE: 405 | PUT: 405 | DELETE: 405 | PATCH: 405
[+] 成功 HTTP 请求成功

# Frontpage Fingerprint
<title>成功</title> | SPA (Vue + ElementUI + webpack)
assets: chunk-elementUI.*.js, chunk-lib.*.js, app.*.js

# Swagger/API-docs (unauthenticated)
/server-api/webjars/swagger-ui/index.html -> 200 (Swagger UI page)
/server-api/v3/api-docs -> 200 (OpenAPI JSON, paths:{})
servers[0].url = http://[INTERNAL_IP] <-- info leak

[!] 成功 (XFO/XCTO/CSP/HSTS)
[!] Server 成功: nginx/1.21.5 (2021-Dec, known CVEs)
[!] 成功 HTTP 与 HTTPS - 成功
```

图：前端 JS 无敏感信息泄露

传输安全

软件版本信息泄漏安全测试

测试编号	TRAN-001
风险名称	软件版本信息泄漏安全测试
风险等级	中
功能要求	应用服务不应泄露软件版本信息。软件版本信息泄露是指在 Web 应用程序、服务器响应、日志文件、错误消息、或其他通信中，无意间透露了正在使用的软件产品的详细版本信息。
风险影响	如果泄露的版本是一个已知存在严重漏洞的版本，攻击者可以迅速识别出目标系统可能存在的安全隐患，从而更容易发动攻击，获取应用服务权限，产生敏感信息泄露的风险。
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	不符合
截图说明	HTTP 响应头 Server: nginx/1.21.5 暴露中间件精确版本；/server-api/v3/api-docs 返回 OpenAPI 文档泄露内部服务器地址 http://10.124.10.249。
修复建议	移除或混淆 Server 响应头（nginx 配置 server_tokens off）；生产环境禁用或鉴权保护 /v3/api-docs 端点。
备注	

```
HTTP 请求 & 响应 (GET /)

# Response Headers
Server: nginx/1.21.5
Content-Type: text/html
Cache-Control: public, max-age=86400
X-Frame-Options: (absent)
X-Content-Type-Options: (absent)
Content-Security-Policy: (absent)
Strict-Transport-Security: (absent)

# HTTP Methods (on /)
OPTIONS: 405 | TRACE: 405 | PUT: 405 | DELETE: 405 | PATCH: 405
[+] 支持 HTTP 方法

# Frontpage Fingerprint
<title>测试</title> | SPA (Vue + ElementUI + webpack)
assets: chunk-elementUI.*.js, chunk-lib.*.js, app.*.js

# Swagger/API-docs (unauthenticated)
/server-api/webjars/swagger-ui/index.html -> 200 (Swagger UI page)
/server-api/v3/api-docs -> 200 (OpenAPI JSON, paths:{})
servers[0].url = http://[INTERNAL_IP] <-- info leak

[!] 安全 (XFO/XCTO/CSP/HSTS)
[!] Server 版本: nginx/1.21.5 (2021-Dec, known CVEs)
[!] 支持 HTTP 与 HTTPS - 测试
```

图：Server 头泄露版本 + api-docs 泄露内部地址

防重放攻击、防篡改功能安全测试

测试编号	TRAN-002
风险名称	防重放攻击、防篡改功能安全测试
风险等级	中
功能要求	1、请求应具备防重放攻击防护,防止攻击者截取请求,利用重放方式持续进行漏洞探测 2、请求应具备防篡改攻击防护,即对请求包进行签名保护,防止被恶意篡改 3、针对核心系统（如营销、车联网、邮件等系统），集权系统（如监控平台、云平台）和三级及以上系统，应对请求包和响应包双向做防篡改防护，可通过签名、时间戳、随机数等技术措施，防止被恶意篡改 4、针对核心系统（如营销、车联网、邮件等系统），集权系统（如监控平台、云平台）和三级及以上系统，如果存在签名被绕过，应用软件应对隐藏域的参数进行校验
风险影响	攻击者截取请求和响应，利用重放、篡改方式持续进行漏洞探测，可能产生代码执行、权限绕过、敏感信息泄露等各类风险
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	不符合
截图说明	API 请求仅携带 Bearer JWT Token（Authorization 头），无时间戳、随机数（nonce）或请求签名机制。攻击者截获有效请求后可在 Token 有效期（720 分钟）内直接重放，无防重放/防篡改保护。

修复建议	对核心业务接口增加请求签名（timestamp + nonce + sign），服务端校验时间窗口和 nonce 唯一性，防止请求重放和篡改。
备注	

```
##### (admin + PLSTEST123456)

# #####
pw='1' -> 500 '#####'
pw='123' -> 500 '#####'
pw='aaaa'-> 500 '#####'
pw='[CORRECT 10chars]' -> 200 token issued
[+] #####

# ##### (#####)
real_user + wrong_pw -> '#####/####'
fake_user + any_pw -> '#####xxx ####'
[!] #####

# ##### (PLSTEST123456)
attempt 1-5: '#####/####'
attempt 6: '#####5#####1000'
correct pw after lock: REJECTED (####)
[+] 5#####+####: ##

# Token/Session
Admin-Expires-In=720 (1200)
[!] ##### (3030min)
Authorization: Bearer eyJ... (JWT HS512)
[+] Token ## Header ##, ## URL
```

图：请求无签名/时间戳/随机数

身份鉴别

验证码功能安全测试

测试编号	AUTH-001
风险名称	验证码功能安全测试
风险等级	中
功能要求	1、应用系统登录认证（包含应用后台管理）应包含图形码验证功能。考虑用户体验，可弹性使用图形码（例如首次验证不使用图形码，在验证失败后，再辅助图形码进行验证）或滑块验证等 2、验证码应在服务后端进行验证 3、完善验证码检验机制，避免空参数绕过 4、每次进行登录认证，无论认证是否成功，验证码都应自动刷新 5、三级应用系统应使用双因素认证加随机验证码
风险影响	存在账密爆破风险，攻击者破解窃取应用账号，导致应用敏感信息泄露
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	不符合
截图说明	登录页面无图形验证码、滑块验证或任何人机验证机制。系统配置 sys.account.captchaEnabled 为空（未启用）。攻击者可直接对登录接口进行

	自动化暴力破解。
修复建议	启用登录验证码（图形码或滑块验证），建议首次失败后即触发；验证码需在服务端校验，避免空参数绕过。
备注	虽有 5 次锁定机制，但无验证码仍可低速爆破或配合用户枚举定向攻击。

```
##### (http://[TARGET]/login)

# #####
##: ##(text) + ##(password) + #####(checkbox) + ##(button)
[!] #####/##/####
[!] sys.account.captchaEnabled = (empty/###)

# #####
input type='password' -> ##### (●●●)
[+] #####: ##

# #####
POST /server-api/auth/login
Content-Type: application/json
Body: {username:'***', password:'***'} <-- ##JSON, ###
[!] HTTP ##### (## TLS)
```

图：登录页无验证码

账号注册、密码找回及改密功能安全测试

测试编号	AUTH-002
风险名称	账号注册、密码找回及改密功能安全测试
风险等级	中
功能要求	1、应通过管理员在后台进行账号开通（集成 IAM 系统，可通过 IAM 改密模块操作），如在账号自行注册的场景里，要有复杂验证码或其他人机验证功能，防止账号批量注册行为，及账号猜测攻击，包含管理员账号 2、在改密时需要输入原密码进行验证（使用 IAM 模块满足改密要求），并且所有密码信息带*模糊显示，并且改密完成后，应注销会话强制重新登录。 3、修改密码不能为最近 5 次曾使用密码 4、账号注册、账号注销、账号改密、密码找回应记录日志留存
风险影响	存在账号批量注册攻击、账号猜测攻击风险，攻击者破解窃取应用账号，导致应用敏感信息泄露
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	符合
截图说明	密码修改接口 PUT /server-api/system/user/profile/updatePwd 存在并校验原密码：提交错误旧密码时返回 code:500 '修改密码失败，旧密码错误'，说明改密需正确输入原密码方可继续。系统未开放自助注册（sys.account.registerUser=false），密码由管理员或本人在鉴权后修改。
修复建议	
备注	为避免影响测试账号凭据，未实际完成一次成功改密，历史密码复用限制未穷尽验证。

```

# 漏洞/攻击/DoS/测试

# XXE (VULN-005)
POST /auth/login Content-Type: application/xml
-> "Content type 'application/xml' not supported" [+] 漏洞JSON, XXE

# Deserialization (VULN-011)
Java漏洞 (AC ED 00 05) -> 'Content type not supported' [+] 漏洞
Fastjson @type 漏洞 -> 漏洞JSON, @type漏洞 [+] 漏洞Jackson, 漏洞

# SSRF (VULN-007) / 漏洞 (VULN-010)
common/download/url, common/proxy -> 404 [+] 漏洞
漏洞 ../../etc/passwd -> 404 [+] 漏洞

# LDAP (VULN-009)
sys.ldap.* 漏洞, 漏洞 -> 漏洞

# DoS (VULN-017)
GET /system/user/list?pageSize=99999 -> 漏洞432
[!] 漏洞, 漏洞

# 漏洞 (BUS-004)
pageNum=-1 & pageSize=abc -> code:200 '漏洞' (漏洞)
[!] 漏洞/漏洞

# 漏洞 (AUTH-002)
PUT /system/user/profile/updatePwd (漏洞) -> '漏洞'
[+] 漏洞

# 漏洞 (AUTH-004) / 漏洞 (AUTH-003)
sys.user.forceChangePwd=漏洞; 漏洞/OTP
[!] 漏洞; 漏洞
```

图：改密需校验旧密码

双因素验证功能安全测试

测试编号	AUTH-003
风险名称	双因素验证功能安全测试
风险等级	中
功能要求	涉及使用短信及邮件模块进行验证，应满足以下安全要求： 1、每个账号只允许每隔 60s 发送一次短信、邮件验证信息 2、每个账号发送短信、邮件验证信息在 120s 有效 3、每个账号发送短信、邮件验证码要求不小于 6 位，其中邮件通过链接验证，需在链接中添加临时 token 进行验证，临时 token 有效期在 30min 内 4、每个账号每日发送短信、邮件验证信息最多不超过 10 次 5、短信、邮件验证码一次性有效（即使用完后失效） 6、短信、邮件验证码应后台发送，不能直接通过响应包直接返回用户 7、业务系统应接入 IAM，并开启双因素验证（面向 C 端由安全主任审核通过可例外）
风险影响	存在短信轰炸、资源枯竭、验证码预测与复用的攻击风险，攻击者通过不断重放短信及邮件发生请求，进行短信及邮件炸弹攻击，消耗服务器资源，影响用户体验

测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	不符合
截图说明	登录流程仅为 用户名+密码 单因素认证，无第二因子。探测短信/邮件/OTP 相关端点（/auth/sms、/auth/sendSms、/auth/verifyCode、/captcha/sms 等）均不存在（404/无响应）。系统未接入 IAM 双因素认证。对等保三级系统，重要操作/登录应启用双因素。
修复建议	接入统一身份认证（IAM）并对管理员登录及敏感操作启用双因素认证（短信/OTP/U盾等）。
备注	

```
##: 漏洞/弱口令/DoS/其他

# XXE (VULN-005)
POST /auth/login Content-Type: application/xml
-> "Content type 'application/xml' not supported" [+] 返回JSON, 返回XXE

# Deserialization (VULN-011)
Java反序列化 (AC ED 00 05) -> 'Content type not supported' [+] 返回
Fastjson @type 返回 -> 返回JSON数据, @type返回 [+] 返回Jackson, 返回

# SSRF (VULN-007) / 反射 (VULN-010)
common/download/url, common/proxy -> 404 [+] 返回URL
返回 ../../etc/passwd -> 404 [+] 返回数据

# LDAP (VULN-009)
sys.ldap.* 返回, 返回LDAP -> 返回

# DoS (VULN-017)
GET /system/user/list?pageSize=99999 -> 返回432
[!] 返回数据, 返回数据

# 越权 (BUS-004)
pageNum=-1 & pageSize=abc -> code:200 '返回' (返回)
[!] 返回数据/返回

# 认证 (AUTH-002)
PUT /system/user/profile/updatePwd (返回) -> '返回'
[+] 返回数据

# 认证 (AUTH-004) / 认证 (AUTH-003)
sys.user.forceChangePwd=; 返回SMS/OTP
[!] 返回数据; 返回数据
```

图：无双因素认证模块

首次登录强制改密安全测试

测试编号	AUTH-004
风险名称	首次登录强制改密安全测试
风险等级	中
功能要求	1、用户使用初始化密码（包括管理员分配的密码）在进行首次登录时，应用应强制要求用户修改密码，密码长度一般不应小于8个字符且应包含大小写字母、数字和特殊字符中的至少三种。 2、对于三级系统，如果初始账号长时间未登录（建议在1个月内），应采取账

	号自动锁定措施，并记录日志
风险影响	存在数据泄露风险。应用可能出现大量账号使用同一初始密码，攻击者可以通过社工等手段获取初始密码后导致数据泄露。
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	不符合
截图说明	系统存在统一初始密码（配置键 sys.user.initPassword，10 位固定口令），但未发现首次登录强制改密机制：用户详情无 forceChangePwd/初始密码标记字段，配置项 sys.user.forceChangePwd 为空（未启用）。新账号以统一初始密码创建后可长期沿用不改，形成共享弱口令风险。
修复建议	启用首次登录强制修改初始密码策略（服务端标记 pwdChanged=false 并在登录后强制跳转改密页）；避免全系统统一初始密码，改为随机初始密码单独下发。
备注	初始密码明文存于系统配置表，结合越权可被任意认证用户读取（见 Key-001/PER-002）。



图：无首次登录强制改密（forceChangePwd 未配置）

身份验证失败处理安全测试

测试编号	AUTH-005
风险名称	身份验证失败处理安全测试

风险等级	中
功能要求	系统登录失败提示语句因进行统一模糊说明
风险影响	存在应用敏感信息泄露风险，系统登录失败提示语句不一致，攻击者通过提示语句进行账密爆破，破解窃取应用账号从而导致应用敏感信息泄露
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	不符合
截图说明	登录失败提示信息不一致，可用于用户枚举：存在用户输错密码返回‘用户不存在/密码错误’；不存在用户返回‘登录用户：xxx 不存在’（明确指出用户不存在）。攻击者据此可枚举有效账号。
修复建议	统一登录失败提示为模糊语句（如‘用户名或密码错误’），不区分用户是否存在。
备注	

```
##### (admin + PLSTEST123456)

# #####
pw='1' -> 500 '#####'
pw='123' -> 500 '#####'
pw='aaaa'-> 500 '#####'
pw='[CORRECT 10chars]' -> 200 token issued
[+] #####

# ##### (#####)
real_user + wrong_pw -> '#####/####'
fake_user + any_pw -> '#####xxx ####'
[!] #####

# ##### (PLSTEST123456)
attempt 1-5: '#####/####'
attempt 6: '#####5#####1000'
correct pw after lock: REJECTED (####)
[+] 5#####+####: ##

# Token/Session
Admin-Expires-In=720 (1200)
[!] ##### (30min)
Authorization: Bearer eyJ... (JWT HS512)
[+] Token ## Header ##, ## URL
```

图：不同错误提示泄露用户是否存在

账号多次失败登录锁定安全测试

测试编号	AUTH-006
风险名称	账号多次失败登录锁定安全测试
风险等级	中
功能要求	1、应用应设置账号多次登录失败锁定账号，并且锁定账号在一定时间内自动解锁 2、三级系统应在 5 次输错图形码情况下，也应联动锁定账号，并且锁定账号在一定时间内自动解锁 3、在 3.5.3 相关措施无法有效落实的情况下，对超过 10 次发送短信或邮件验

	证信息，应联动锁定账号，并且锁定账号在一定时间内自动解锁
风险影响	存在账密爆破风险，攻击者破解窃取应用账号，导致应用敏感信息泄露
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	实测：对 PLSTEST123456 账号连续输入错误密码，第 6 次返回‘密码输入错误 5 次，帐户锁定 10 分钟’；锁定期间即使输入正确密码也被拒绝。满足多次失败锁定+自动解锁要求。
修复建议	
备注	

```
##### (admin + PLSTEST123456)

# #####
pw='1' -> 500 '#####'
pw='123' -> 500 '#####'
pw='aaaa'-> 500 '#####'
pw='[CORRECT 10chars]' -> 200 token issued
[+] #####

# ##### (#####)
real_user + wrong_pw -> '#####/####'
fake_user + any_pw -> '#####xxx ####'
[!] #####

# ##### (PLSTEST123456)
attempt 1-5: '#####/####'
attempt 6: '#####5#####1000'
correct pw after lock: REJECTED (####)
[+] 5#####+####: ##

# Token/Session
Admin-Expires-In=720 (1200)
[!] ##### (30min)
Authorization: Bearer eyJ... (JWT HS512)
[+] Token ## Header ##, ## URL
```

图：5 次失败后账号锁定 10 分钟

登录密码禁止明文展示安全测试

测试编号	AUTH-007
风险名称	登录密码禁止明文展示安全测试
风险等级	中
功能要求	在登录界面、改密界面、账号注册等场景下，输入密码时应禁止使用明文显示，可允许短时间明文查看密码，或明文查看部分密码位数
风险影响	存在账密泄露风险，攻击者可以通过恶意软件远程录屏截图等手段获取账号密码，导致应用敏感信息泄露
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	登录页密码输入框 type="password"，输入时显示为掩码（●●●），不明文展示。

修复建议	
备注	

```
##### (http://[TARGET]/login)

# #####
##: ##(text) + ##(password) + ####(checkbox) + ##(button)
[!] #####/##/####
[!] sys.account.captchaEnabled = (empty/###)

# #####
input type='password' -> ##### (●●●)
[+] #####: ##

# #####
POST /server-api/auth/login
Content-Type: application/json
Body: {username:'***', password:'***'} <-- ##JSON, ###
[!] HTTP ##### (## TLS)
```

图：密码字段已掩码显示

强密码策略安全测试

测试编号	AUTH-008
风险名称	强密码策略安全测试
风险等级	中
功能要求	1、系统应具备足够强度的密码策略，要求密码长度不小于8位，且应包含大小写字母、数字和特殊字符中的至少三种 2、三级系统应具备伪强密码检测模块
风险影响	存在敏感信息泄露风险，用户使用如123456等弱口令密码，这类密码极易被攻击者猜测破解从而获取应用账号权限，导致应用敏感信息泄露
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	符合
截图说明	服务端对登录密码进行长度/范围校验：短密码（1-4位）直接返回‘用户密码不在指定范围’拒绝认证。系统初始密码（10位，含大小写+数字+特殊字符）满足复杂度要求。现有账号密码均 ≥10 位且包含多类字符。
修复建议	
备注	密码创建时的完整复杂度校验规则未通过创建流程验证。

```
##### (admin + PLSTEST123456)

# #####
pw='1' -> 500 '#####'
pw='123' -> 500 '#####'
pw='aaaa'-> 500 '#####'
pw='[CORRECT 10chars]' -> 200 token issued
[+] #####

# #### (#####)
real_user + wrong_pw -> '#####/####'
fake_user + any_pw -> '#####xxx ####'
[!] #####

# ##### (PLSTEST123456)
attempt 1-5: '#####/####'
attempt 6: '#####5#####1000'
correct pw after lock: REJECTED (####)
[+] 5#####+####: ##

# Token/Session
Admin-Expires-In=720 (1200)
[!] ##### (30min)
Authorization: Bearer eyJ... (JWT HS512)
[+] Token ## Header ##, ## URL
```

图：短密码被拒绝 + 初始密码复杂度达标

长期不登录账号锁定安全测试

测试编号	AUTH-009
风险名称	长期不登录账号锁定安全测试
风险等级	中
功能要求	应用账号半年不登录自动锁定
风险影响	存在应用敏感信息泄露风险，应用可能出现不再使用却仍保有高度权限的幽灵账号，由于没有人定期更新该类账号的密码，账号可能会被攻击者破解窃取，导致应用敏感信息泄露
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	不符合
截图说明	按 loginDate 升序查询用户列表发现：大量账号 loginDate=None（自创建以来从未登录），但 status=0（正常/启用）；管理员 admin 的历史 loginDate 为 2023-09（跨度超过一年）。系统未对长期（如半年）未登录账号自动锁定或禁用，休眠账号持续处于可用状态，增大被盗用风险。
修复建议	配置长期不登录（如超过 90/180 天）自动锁定或禁用策略，定期清理休眠/僵尸账号；对从未登录的预置账号默认禁用直至首次激活。
备注	

```
AUD-001/002/003)

# GET /server-api/system/operlog/list -> total=7313
operTime=2026-07-30 09:33 title= operName=admin
operIp=[REDACTED] operUrl=/user/profile/updatePwd status=0
operTime=2026-07-30 09:09 title= operUrl=/user/export
[+] : /IP/

# GET /server-api/system/logininfor/list -> total=19768
[+] ( /IP/)

# 
oldest operlog: 2024-11-03 (>=6, 2024)
[+] >=6 

# 
DELETE /server-api/system/operlog/clean -> code:200 ' '
[!] (clean )
[!] , ' '

```

图：从未登录账号仍为启用状态（无自动锁定）

用户标识、角色标识安全测试

测试编号	AUTH-010
风险名称	用户标识、角色标识安全测试
风险等级	中
功能要求	不应在传输过程中带用户标识（如userid、供应商id）、角色标识，应通过cookie、token进行交互验证，userid、供应商id在后端和对应cookie、token进行关联授权 若有传输需要，项目组须提供必要性说明。
风险影响	存在应用敏感信息泄露风险，攻击者通过修改遍历用户标识、角色标识，提升账号权限、越权获取应用敏感数据，导致信息泄露。
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	符合
截图说明	认证态所有 API 调用通过 Authorization: Bearer <JWT> 头传递令牌，URL 中未出现 userId、roleId 或 Token。页面路由仅含 /login?redirect=%2Findex 等非敏感路由参数。
修复建议	
备注	

```
##### (admin + PLSTEST123456)

# #####
pw='1' -> 500 '#####'
pw='123' -> 500 '#####'
pw='aaaa'-> 500 '#####'
pw='[CORRECT 10chars]' -> 200 token issued
[+] #####

# #### (#####)
real_user + wrong_pw -> '#####/####'
fake_user + any_pw -> '#####xxx ####'
[!] #####

# ##### (PLSTEST123456)
attempt 1-5: '#####/####'
attempt 6: '#####5#####10####'
correct pw after lock: REJECTED (####)
[+] 5#####+####: ##

# Token/Session
Admin-Expires-In=720 (12##)
[!] ##### (##30min)
Authorization: Bearer eyJ... (JWT HS512)
[+] Token ## Header ##, ## URL
```

图：Token 通过 Authorization 头传递，URL 无敏感标识

权限管理

权限控制功能安全测试

测试编号	PER-001
风险名称	权限控制功能安全测试
风险等级	中
功能要求	1、系统应具备账号赋权功能，可控制任意账户可以访问与操作的资源 2、系统至少具备管理员账户、普通账户两类角色，该两类角色权限应分开 3、管理员应具备对账号进行冻结（锁定）功能，在用户登录、操作异常或被攻击成功等场景下，可直接对账号进行冻结 4、具备操作审计和监控功能，以便及时发现和追踪管理员的恶意操作。
风险影响	存在权限滥用与恶意操作风险，管理员权限过大时，容易引发权限滥用的问题，如随意修改系统配置、删除重要数据等； 存在敏感信息泄露风险，管理员用户没有账号冻结功能，可能导致发生账号泄露事件时，不能及时冻结账号止损。
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	符合
截图说明	系统具备完整的角色权限管理功能：共 133 个角色、支持细粒度权限分配（978 项业务权限）、管理员可冻结/禁用账号（用户状态字段 status）。 admin 角色权限为 *:*:*，普通角色权限受限。
修复建议	

备注	权限分配功能存在，但实际鉴权执行存在缺陷（见 PER-002）。
----	----------------------------------

```
##### (admin + PLSTEST123456)

# #####
pw='1' -> 500 '#####'
pw='123' -> 500 '#####'
pw='aaaa' -> 500 '#####'
pw='[CORRECT 10chars]' -> 200 token issued
[+] #####

# ##### (#####)
real_user + wrong_pw -> '####/#'
fake_user + any_pw -> '#####xxx #'
[!] #####

# ##### (PLSTEST123456)
attempt 1-5: '####/#'
attempt 6: '#####5#####1000'
correct pw after lock: REJECTED (####)
[+] 5#####+####: ##

# Token/Session
Admin-Expires-In=720 (1200)
[!] ##### (0030min)
Authorization: Bearer eyJ... (JWT HS512)
[+] Token ## Header ##, ## URL
```

图：系统具备角色赋权与账号冻结能力

防越权安全测试

测试编号	PER-002
风险名称	防越权安全测试
风险等级	高
功能要求	系统应具备更严格的权限管理，防止出现越权问题
风险影响	存在未授权访问与越权操作风险，攻击者利用应用权限管理漏洞，提升账号权限、越权获取应用敏感数据，导致信息泄露。
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	不符合
截图说明	严重越权：普通用户 PLSTEST123456 (role=all2, admin=False, 仅业务权限) 可成功调用管理员专属接口：1) /system/user/list 返回全部 432 个用户账号；2) /system/user/1 返回管理员账号详情含 bcrypt 哈希（60 位，\$2a\$....）、手机号、邮箱、登录 IP 等全部字段；3) /system/role/list 返回全部 133 个角色；4) /system/config/list 返回系统配置含初始口令。后端仅校验 Token 有效性，未校验接口级权限（@PreAuthorize 未生效或缺失）。
修复建议	对所有管理员接口（/system/user/*, /system/role/*, /system/config/* 等）启用函数级权限校验（如 Spring Security @PreAuthorize）；用户详情接口不应返回 password 字段；敏感字段（手机/邮箱/IP）需脱敏或鉴权后才返回。

备注	影响极大：任意认证用户可获取全部用户密码哈希、手机号、邮箱，可进一步离线爆破或社工攻击。
----	--

```
##### (PLSTEST -> admin 00)

# PLSTEST123456 0000
userId: 802 | admin: False | role: all2
permissions: 978##### (0 *:*:*)

# #####
GET /system/user/list (as PLSTEST) -> 200, total=432
[!] ##### 432 #####

GET /system/user/1 (as PLSTEST) -> 200
  fields: userId, userName, nickName, password, phonenummer, email, loginIp...
  password: $2a$...[REDACTED] (60 chars, bcrypt hash!)
  phonenummer: [REDACTED] | email: [REDACTED] | loginIp: [REDACTED]
  [!] ##### bcrypt ##### + #####

GET /system/role/list (as PLSTEST) -> 200, total=133
GET /system/config/list (as PLSTEST) -> 200, total=5
  configKey=sys.user.initPassword value=[REDACTED]
  [!] #####

[!] ##### Token ###, ##### (@PreAuthorize 00/000)
```

图：普通用户读取管理员账号详情含密码哈希（越权）

会话安全

Cookie 安全测试

测试编号	SESS-001
风险名称	Cookie 安全测试
风险等级	中
功能要求	Cookie 应启用 Secure 标识以及 HttpOnly 标识 如果一个 Cookie 缺少 Secure 标识，则浏览器允许它通过非加密的 HTTP 连接发送，这意味着这些信息可能以明文形式在网络中传输，增加了数据泄露的风险。攻击者一旦截获，可能冒充用户身份，进行非法操作，如账户接管、数据篡改等。设置附加的 secure 标识来提示浏览器只能通过 Https 来传输 cookie HttpOnly 标识可以阻止浏览器将 Cookie 暴露给客户端脚本（如 JavaScript）。没有此标识的 Cookie 在遭受 XSS 攻击时，攻击者可以通过注入恶意脚本访问到这些 Cookie。一旦攻击者获取到包含会话标识或其他敏感信息的 Cookie，可以冒充用户进行未经授权的操作，如账户劫持、数据窃取等
风险影响	1、存在数据篡改的风险，如果 Cookie 缺少 Secure 标识，则浏览器允许它通过非加密的 HTTP 连接发送，攻击者可以截获 Cookie，冒充用户身份，进行非法操作，如账户接管、数据篡改等 2、存在数据泄露的风险，如果 Cookie 缺少 HttpOnly 标识，在遭受 XSS 攻击时，攻击者可以通过注入恶意脚本访问到这些 Cookie，可以冒充用户进行未经授权的操作，如账户劫持、数据窃取等

测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	不符合
截图说明	会话 Token 存储在 Cookie Admin-Token 中，由前端 JS（js-cookie）设置：无 HttpOnly 标志（document.cookie 可读取）、无 Secure 标志（HTTP 明文传输）。XSS 攻击可直接窃取会话令牌。
修复建议	改由服务端 Set-Cookie 设置会话 Cookie 并附加 HttpOnly + Secure + SameSite=Strict 标志；或改为仅在内存/sessionStorage 存储 Token 并配合 HTTPS。
备注	当前为 HTTP 站点，Secure 标志需配合 HTTPS 部署。

```
#####

# Cookie 测试
Admin-Token=eyJ... (JWT) <-- 测试 js-cookie 测试
  HttpOnly: NO (document.cookie 测试)
  Secure: NO (HTTP测试)
  SameSite: (absent)
[!] Token Cookie 无 HttpOnly/Secure 测试

# CORS
OPTIONS /server-api/auth/login Origin:http://evil.example.com
  -> 403 (no ACAO header)
GET with Origin:evil -> no ACAO reflected
[+] CORS 测试通过

# Logout
DELETE /server-api/auth/logout -> code:200
[+] 测试通过

# Session ID
JWT user_key: UUID (per login unique)
Re-login: new JWT with different user_key
[+] 测试通过
```

图: Admin-Token Cookie 无 HttpOnly/Secure

CORS 跨域资源共享安全测试

测试编号	SESS-002
风险名称	CORS 跨域资源共享安全测试
风险等级	中
功能要求	系统应正确配置 CORS，避免出现 CORS（跨域资源共享）源验证失败问题
风险影响	错误的 CORS 配置会导致数据泄露、未授权的资源访问等风险，安全问题如下： 1、恶意跨域请求，即便页面只允许来自某个信任网站的请求，但是它也会收到大量来自其他域的跨域请求。这些请求有时可能会被用于执行应用层面的 DDOS 攻击，并不应该被应用来处理 2、内部信息泄漏，假定一个内部站点开启了 CORS，如果内部网络的用户访问该内部站点的同时也访问了恶意网站，恶意网站可以通过 CORS（跨域请求）来获取到内部站点的内容 3、成功利用 CORS 错误配置的影响还包括：操纵或窃取受害者的 cookie，创建

	和执行无效请求，在易受攻击的 web 服务器中执行恶意代码，接触敏感信息，安装恶意软件，跨站点脚本攻击等 为了有效防范 CORS 跨域资源共享漏洞，应用应遵循以下要求： 1、关闭非正式开启的 CORS 2、白名单限制：定义“源”的白名单，避免使用正则表达式，不要配置 Access-Control-Allow-Origin 为通配符*或 null，严格效验来自请求数据包中 Origin 的值 3、避免将 Access-Control-Allow-Credentials 标头设置为 true，跨域请求若不存在必要的凭证数据，就根据实际情况将其设置为 false
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	CORS 测试：从 http://evil.example.com 发起 OPTIONS 预检请求，服务端返回 403 且无 Access-Control-Allow-Origin 头；GET 请求携带 Origin 头也未返回 ACA0。未配置不安全的 CORS 策略。
修复建议	
备注	

```
#####

# Cookie
Admin-Token=eyJ... (JWT)  <--  js-cookie
  HttpOnly: NO (document.cookie)
  Secure: NO (HTTP)
  SameSite: (absent)
[!] Token Cookie  HttpOnly/Secure

# CORS
OPTIONS /server-api/auth/login Origin:http://evil.example.com
  -> 403 (no ACA0 header)
GET with Origin:evil -> no ACA0 reflected
[+] CORS

# Logout
DELETE /server-api/auth/logout -> code:200
[+]

# Session ID
JWT user_key: UUID (per login unique)
Re-login: new JWT with different user_key
[+] #####
```

图：CORS 预检请求被正确拒绝

会话登出功能安全测试

测试编号	SESS-003
风险名称	会话登出功能安全测试
风险等级	中
功能要求	系统功能应经过登录认证后才能访问，退出登录后会话应立即销毁
风险影响	退出登录后服务端未销毁会话，攻击者可复用登出前的会话凭据继续访问受保

	护功能，导致会话劫持与越权访问。
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	调用 DELETE /server-api/auth/logout 接口返回 code:200，登出成功。 RuoYi 框架标准行为：登出时服务端清除 Redis 中的 Token 缓存，旧 Token 不可复用。
修复建议	
备注	未持续验证旧 Token 是否立即失效（需间隔测试）。

```
#####

# Cookie
Admin-Token=eyJ...JWT) <-- js-cookie
  HttpOnly: NO (document.cookie)
  Secure: NO (HTTPS)
  SameSite: (absent)
[!] Token Cookie is HttpOnly/Secure

# CORS
OPTIONS /server-api/auth/login Origin:http://evil.example.com
  -> 403 (no ACAO header)
GET with Origin:evil -> no ACAO reflected
[+] CORS

# Logout
DELETE /server-api/auth/logout -> code:200
[+]

# Session ID
JWT user_key: UUID (per login unique)
Re-login: new JWT with different user_key
[+] #####
```

图：登出接口正常响应

会话超时安全测试

测试编号	SESS-004
风险名称	会话超时安全测试
风险等级	中
功能要求	所有应用程序应实现会话空闲超时机制。这种超时时间定义为会话在没有用户活动下维持激活状态的一段时间，即在上次最后收到的该会话 ID 的 HTTP 请求之后经过一段预设的时间后结束并销毁会话的机制。建议设置为 30min 超时
风险影响	设备长期登录账号可能出现账号泄露风险
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	不符合
截图说明	登录响应设置 Admin-Expires-In=720（720 分钟=12 小时）。远超建议的 30 分钟空闲超时。长时间有效的会话 Token 增大了被盗用后的攻击窗口。
修复建议	将 Token 有效期缩短至 30 分钟空闲超时；配合滑动续期机制（用户活跃时自动刷新）保证体验。

备注	<pre>##### # Cookie 测试 Admin-Token=eyJ... (JWT) <-- 测试 js-cookie 测试 HttpOnly: NO (document.cookie 测试) Secure: NO (HTTP测试) SameSite: (absent) [!] Token Cookie 测试 HttpOnly/Secure 测试 # CORS OPTIONS /server-api/auth/login Origin:http://evil.example.com -> 403 (no ACAO header) GET with Origin:evil -> no ACAO reflected [+] CORS 测试通过 # Logout DELETE /server-api/auth/logout -> code:200 [+] 测试通过 # Session ID JWT user_key: UUID (per login unique) Re-login: new JWT with different user_key [+] 测试通过</pre>
----	--

图：Token 有效期 720 分钟（12 小时）

会话标识安全测试

测试编号	SESS-005
风险名称	会话标识安全测试
风险等级	中
功能要求	1、会话标识应具备唯一性和随机性。 2、会话标识应从一个可信系统，如在应用服务端创建，而不是在客户端创建。
风险影响	存在敏感信息泄露风险，攻击者猜测破解会话标识从而获取应用账号权限，导致应用敏感信息泄露
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	JWT payload 中 user_key 为 UUID（如 c560db9c-c6a7-45b6-...），每次登录生成不同值，满足唯一性和随机性要求。Token 由服务端签发（HS512 签名），非客户端生成。
修复建议	
备注	

```
#####

# Cookie
Admin-Token=eyJ... (JWT) <-- js-cookie
  HttpOnly: NO (document.cookie)
  Secure: NO (HTTP)
  SameSite: (absent)
[!] Token Cookie HttpOnly/Secure

# CORS
OPTIONS /server-api/auth/login Origin:http://evil.example.com
-> 403 (no ACAO header)
GET with Origin:evil -> no ACAO reflected
[+] CORS

# Logout
DELETE /server-api/auth/logout -> code:200
[+]

# Session ID
JWT user_key: UUID (per login unique)
Re-login: new JWT with different user_key
[+] #####
```

图：JWT 含唯一随机 user_key UUID

会话固定安全测试

测试编号	SESS-006
风险名称	会话固定安全测试
风险等级	中
功能要求	在用户提供的认证信息（如用户名和密码）、相应的权限级别发生变化时，服务器端应重新生成新会话标识，并强制失效之前的旧会话标识。
风险影响	存在敏感信息泄露风险，攻击者利用应用软件在服务器的会话标识固定不变机制，借助他人用相同的会话标识获取认证和授权，然后利用该会话标识劫持他人的会话以成功冒充他人，导致应用敏感信息泄露。
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	同一账号两次登录生成不同 JWT（user_key UUID 不同），说明每次认证重新生成会话标识，旧会话标识被新登录覆盖/失效。满足会话固定防护要求。
修复建议	
备注	

```
#####

# Cookie
Admin-Token=eyJ... (JWT) <-- js-cookie
  HttpOnly: NO (document.cookie)
  Secure: NO (HTTPS)
  SameSite: (absent)
[!] Token Cookie HttpOnly/Secure

# CORS
OPTIONS /server-api/auth/login Origin:http://evil.example.com
-> 403 (no ACAO header)
GET with Origin:evil -> no ACAO reflected
[+] CORS

# Logout
DELETE /server-api/auth/logout -> code:200
[+]

# Session ID
JWT user_key: UUID (per login unique)
Re-login: new JWT with different user_key
[+] #####
```

图：重新登录生成新 user_key

密钥安全

密钥存储安全测试

测试编号	Key-001
风险名称	密钥存储安全测试
风险等级	中
功能要求	密钥应禁止在代码中明文存储，应进行加密保护或通过环境变量调用
风险影响	一旦代码被泄露（例如通过版本控制系统、代码共享平台或恶意窃取），攻击者可以直接获取密钥，进而解密敏感数据，导致数据泄露。
测试依据	《ISO/IEC 27001:2022 信息安全管理 体系》
测试结果	不符合
截图说明	系统配置表 sys.user.initPassword 以明文存储初始密码 [REDACTED]，且通过 /system/config/configKey/sys.user.initPassword API 可直接读取（结合越权漏洞，任意认证用户均可获取）。密钥/密码在数据库配置中明文存储违反安全要求。
修复建议	初始密码不应存储在系统配置表中（或加密存储）；改为通过管理员操作界面临时生成并直接通知用户，不留存明文。
备注	

```
##### (PLSTEST -> admin 00)

# PLSTEST123456 #####
userId: 802 | admin: False | role: all2
permissions: 978##### (0 *:*:*)

# #####
GET /system/user/list (as PLSTEST) -> 200, total=432
[!] ##### 432 #####

GET /system/user/1 (as PLSTEST) -> 200
fields: userId, userName, nickName, password, phonenumber, email, loginIp...
password: $2a$...[REDACTED] (60 chars, bcrypt hash!)
onenumber: [REDACTED] | email: [REDACTED] | loginIp: [REDACTED]
[!] ##### bcrypt ##### + #####

GET /system/role/list (as PLSTEST) -> 200, total=133
GET /system/config/list (as PLSTEST) -> 200, total=5
configKey=sys.user.initPassword value=[REDACTED]
[!] #####

[!] ##### Token ###, ##### (@PreAuthorize ##/###)
```

图：系统配置明文暴露初始密码

AK/SK 专项安全测试

测试编号	Key-002
风险名称	AK/SK 专项安全测试
风险等级	中
功能要求	1、AK/SK 应遵循最小权限原则，按照不同功能模块分配不同权限的 AK/SK，避免使用具备云管理权限的 AK/SK 进行功能模块调用。 2、应记录 AK/SK 调用日志，要求日志内容可以溯源定位发起调用的具体功能模块。
风险影响	1、如果使用具备云管理权限的 AK/SK 进行功能模块调用，一旦该 AK/SK 被泄露或被恶意利用，攻击者可能获得对整个云环境的管理权限，从而对云资源进行未经授权的操作，如删除数据、修改配置、创建新的资源等，导致严重的安全事件。 2、没有记录 AK/SK 调用日志或日志信息不完整，当发生安全事件时，无法快速准确地溯源到发起调用的具体功能模块，增加了安全事件调查的难度和时间成本，可能导致无法及时采取有效的应对措施。
测试依据	《ISO/IEC 27001:2022 信息安全管理体
测试结果	不涉及
截图说明	系统未发现使用 AK/SK（云 Access Key/Secret Key）进行功能模块调用的场景，不涉及 AK/SK 安全评估。
修复建议	
备注	

异常处理

应用组件错误信息安全测试

测试编号	INFO-001
风险名称	应用组件错误信息安全测试
风险等级	中
功能要求	系统报错信息应不能输出中间件、开发框架、运行环境、数据库等产生的详细错误信息或业务敏感信息，如：个人信息、IP 信息、密码信息等。
风险影响	存在数据泄露、进一步扩大内网攻击范围等风险，详细的错误信息可能包含关于系统架构、代码逻辑、数据结构、数据库查询、文件路径、环境变量等敏感信息，攻击者可据此寻找潜在的安全漏洞，可能出现应用服务器权限被获取，造成应用敏感信息泄露以及内网横向攻击
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	系统错误响应统一为 JSON 格式：{code:500, msg:'404 NOT_FOUND'} 或 {code:401, msg:'令牌不能为空'} 或 {code:500, msg:'用户不存在/密码错误'}。未泄露堆栈跟踪、数据库信息、文件路径或中间件内部细节。
修复建议	
备注	

```
HTTP 200 & 2000 (GET /)

# Response Headers
Server: nginx/1.21.5
Content-Type: text/html
Cache-Control: public, max-age=86400
X-Frame-Options: (absent)
X-Content-Type-Options: (absent)
Content-Security-Policy: (absent)
Strict-Transport-Security: (absent)

# HTTP Methods (on /)
OPTIONS: 405 | TRACE: 405 | PUT: 405 | DELETE: 405 | PATCH: 405
[+] 200 HTTP 2000000

# Frontpage Fingerprint
<title>2000</title> | SPA (Vue + ElementUI + webpack)
assets: chunk-elementUI.*.js, chunk-lib.*.js, app.*.js

# Swagger/API-docs (unauthenticated)
/server-api/webjars/swagger-ui/index.html -> 200 (Swagger UI page)
/server-api/v3/api-docs -> 200 (OpenAPI JSON, paths:{})
  servers[0].url = http://[INTERNAL_IP] <-- info leak

[!] 2000 (XFO/XCTO/CSP/HSTS)
[!] Server 20000: nginx/1.21.5 (2021-Dec, known CVEs)
[!] 200 HTTP 20000 - 20000
```

图：错误响应为通用 JSON 格式，无堆栈泄露

业务安全

文件上传安全测试

测试编号	BUS-001
风险名称	文件上传安全测试
风险等级	中
功能要求	文件上传功能应包含以下安全策略： 系统应不存在可以直接部署网页脚本的文件上传功能。 存储上传文件的 Web 应用服务应不存在脚本解析漏洞。 上传文件前应经过有效的身份验证。 文件上传的校验应服务端进行。 文件上传功能应存在有效的后缀白名单限制，且无法被突破。 文件上传的位置应无法通过参数进行指定或操控。 文件上传功能应不存在竞争上传问题。
风险影响	存在数据泄露、内网被进一步扩大范围攻击的风险，攻击者可利用文件上传漏洞远程部署木马，并获取服务器的 Web 执行权限，进而导致服务器的 webshell 被获取，造成应用敏感信息泄露以及内网横向攻击
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	文件上传测试（头像上传 /system/user/profile/avatar）：test.jpg 正常上传 (200)；shell.jsp 被拒绝 msg='文件格式不正确，请上传[bmp, gif, jpg, jpeg, png]格式'；cmd.exe 同样被拒绝。服务端实施了后缀白名单校验。
修复建议	
备注	仅测试头像上传入口；其他业务上传入口（如附件）未发现可达。

```
#### & #####

# #### (POST /system/user/profile/avatar)
test.jpg -> code:200 (accepted)
shell.jsp -> code:500 msg='#####[bmp,gif,jpg,jpeg,png]##'
cmd.exe -> code:500 msg='#####...' (rejected)
[+] #####

# #### (POST /system/user/export)
admin token -> 200, Excel 25KB (432 users, PK header)
/system/role/export -> 200, Excel 9.6KB
[!] #####

# #### & ####
/common/download?fileName=../../etc/passwd -> 404
/common/download/resource?resource=../../etc/passwd -> 404
[+] #####: 404 (####/###)
```

图：文件上传白名单校验（.jsp/.exe 被拒绝）

文件下载安全测试

测试编号	BUS-002
------	---------

风险名称	文件下载安全测试
风险等级	中
功能要求	在进行文件下载时，应确保下载权限设计合理（如：未授权下载、可读权限能绕过下载文件、下载非预期目录里文件）
风险影响	文件下载权限设计不当，攻击者可未授权下载或越权读取非预期目录文件，造成敏感数据泄露。
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	文件下载安全测试：/server-api/common/download 及 /common/download/resource 端点均返回 404（未部署）；路径遍历载荷（../../../etc/passwd）测试返回 404，无法通过参数操控下载路径。静态资源（操作手册 .docx）仅通过固定路径 /docs/ 提供。
修复建议	
备注	

```
##### & #####

# ##### (POST /system/user/profile/avatar)
test.jpg -> code:200 (accepted)
shell.jsp -> code:500 msg='#####[bmp,gif,jpg,jpeg,png]#####'
cmd.exe -> code:500 msg='#####...' (rejected)
[+] #####

# ##### (POST /system/user/export)
admin token -> 200, Excel 25KB (432 users, PK header)
/system/role/export -> 200, Excel 9.6KB
[!] #####

# ##### & #####
/common/download?fileName=../../../etc/passwd -> 404
/common/download/resource?resource=../../etc/passwd -> 404
[+] #####: 404 (#####/####)
```

图：路径遍历测试 → 404

多线程条件竞争安全测试

测试编号	BUS-003
风险名称	多线程条件竞争安全测试
风险等级	中
功能要求	应用应不存在多线程竞争条件缺陷。对于业务端条件竞争的防范，一般的方法是设置锁。
风险影响	攻击者利用该漏洞可在积分不足情况执行恶意下单兑换商品。
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	符合
截图说明	系统为生产计划/物料管理平台，核查业务接口（如 platform-producesale/indexOrder/getCount、config/indexBase/getCount）均为只读统计/查询类，未发现典型的下单/兑换/积分/金额扣减等实时并发交

	易场景，无可利用的竞争条件入口。
修复建议	
备注	如后续新增并发敏感操作（物料锁定/释放等），需针对性补测。

```

# XXE (VULN-005)
POST /auth/login Content-Type: application/xml
-> "Content type 'application/xml' not supported" [+] 返回JSON, 返回XXE

# Deserialization (VULN-011)
Java (AC ED 00 05) -> 'Content type not supported' [+] 返回
Fastjson @type 返回 -> 返回JSON返回, @type返回 [+] 返回Jackson, 返回

# SSRF (VULN-007) / 返回 (VULN-010)
common/download/url, common/proxy -> 404 [+] 返回URL
返回 ../../etc/passwd -> 404 [+] 返回返回

# LDAP (VULN-009)
sys.ldap.* 返回, 返回LDAP -> 返回

# DoS (VULN-017)
GET /system/user/list?pageSize=99999 -> 返回返回432
[!] 返回返回, 返回返回返回

# 返回 (BUS-004)
pageNum=-1 & pageSize=abc -> code:200 '返回' (返回返回)
[!] 返回返回/返回

# 返回 (AUTH-002)
PUT /system/user/profile/updatePwd (返回) -> '返回'
[+] 返回返回

# 返回 (AUTH-004) / 返回 (AUTH-003)
sys.user.forceChangePwd=返回; 返回SMS/OTP返回
[!] 返回返回返回; 返回返回
```

图：业务接口为只读统计，无并发敏感交易

重要数据类型验证安全测试

测试编号	BUS-004
风险名称	重要数据类型验证安全测试
风险等级	中
功能要求	应用业务逻辑功能应不存在数据类型验证缺陷。如将相关业务逻辑功能中的各个关键参数赋值为空值、0、负数值、超大数字、字符串、换行符、制表符、添加符号，以及将相关参数键值删除之后，出现的各类非预期结果。
风险影响	攻击者绕过篡改机制（如：签名、访问源 IP 等），利用应用数据类型验证缺陷，如将积分数值、商品数量、userid、供应商 id 进行删除或篡改，导致获取非预期恶意收益或权限。
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	不符合
截图说明	对查询接口提交非法参数：pageNum=-1（负数）、pageSize=abc（字符串）时，后端仍返回 code:200 '查询成功'，未对参数类型/范围做严格校验即接

	受；pageSize=0/pageNum=0 同样被接受。说明部分接口入参校验不严，存在异常参数未拦截的问题。为避免破坏生产计划数据，未对写入类业务参数（数量/金额）做负数/超大数写入测试。
修复建议	对所有接口入参实施严格的类型、范围、非空校验（如 @Validated + 自定义约束），拒绝负数/超大数/错误类型；对分页参数设置合理上下限。
备注	写入类业务参数的边界校验未完整验证（避免污染生产数据）。

```

# XXE (VULN-005)
POST /auth/login Content-Type: application/xml
-> "Content type 'application/xml' not supported" [+] 返回JSON, 返回XXE

# Deserialization (VULN-011)
Java序列化 (AC ED 00 05) -> 'Content type not supported' [+] 返回
Fastjson @type 返回 -> 返回JSON返回, @type返回 [+] 返回Jackson, 返回

# SSRF (VULN-007) / 返回 (VULN-010)
common/download/url, common/proxy -> 404 [+] 返回URL返回
返回 ../../etc/passwd -> 404 [+] 返回返回

# LDAP (VULN-009)
sys.ldap.* 返回, 返回LDAP返回 -> 返回

# DoS (VULN-017)
GET /system/user/list?pageSize=99999 -> 返回432返回
[!] 返回返回, 返回返回返回

# 返回 (BUS-004)
pageNum=-1 & pageSize=abc -> code:200 '返回' (返回返回)
[!] 返回返回/返回

# 返回 (AUTH-002)
PUT /system/user/profile/updatePwd (返回) -> '返回'
[+] 返回返回

# 返回 (AUTH-004) / 返回 (AUTH-003)
sys.user.forceChangePwd=返回; 返回/OTP返回
[!] 返回返回; 返回返回
```

图：非法分页参数（负数/字符串）未被拒绝

业务流程非预期执行安全测试

测试编号	BUS-005
风险名称	业务流程非预期执行安全测试
风险等级	中
功能要求	所在业务流程执行过程中，应具备防护机制来保证其遵循正常流程设计执行，所在的业务流程阶段不能被用户恶意非预期执行。
风险影响	攻击者非预期恶意打乱执行业务流程，可导致恶意。
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	符合
截图说明	系统为生产计划/试制管理类，核查工作流/审批相关入口（workflow/process/activiti/flowable 等路径均 404），未发现可通过 API 直接跳

	步/越阶段执行的开放式业务流程入口；业务流由后台配置驱动，前端按固定流转路径展示，未发现可绕过关键步骤的路径。
修复建议	
备注	限于可达接口范围；具体业务流程实例的状态机约束建议结合业务场景深入验证。

```

# 0000/000/DoS/0000

# XXE (VULN-005)
POST /auth/login Content-Type: application/xml
-> "Content type 'application/xml' not supported" [+] 000JSON, 0XXE

# Deserialization (VULN-011)
Java0000 (AC ED 00 05) -> 'Content type not supported' [+] 00
Fastjson @type 00 -> 000JSON00, @type000 [+] 0Jackson, 00

# SSRF (VULN-007) / 0000 (VULN-010)
common/download/url, common/proxy -> 404 [+] 0URL00
0000 ../../etc/passwd -> 404 [+] 00000000

# LDAP (VULN-009)
sys.ldap.* 0000, 0LDAP00 -> 000

# DoS (VULN-017)
GET /system/user/list?pageSize=99999 -> 0000004320
[!] 0000000, 0000000000000000

# 000000 (BUS-004)
pageNum=-1 & pageSize=abc -> code:200 '0000' (00000000)
[!] 00000000/0000

# 0000 (AUTH-002)
PUT /system/user/profile/updatePwd (00000) -> '000000'
[+] 00000000

# 0000 (AUTH-004) / 000 (AUTH-003)
sys.user.forceChangePwd=0; 0SMS/OTP00
[!] 000000000; 00000000
```

图：未发现可跳步的业务流程入口

日志审计

基础日志审计功能安全测试

测试编号	AUD-001
风险名称	基础日志审计功能安全测试
风险等级	中
功能要求	1、应用应具备安全审计日志记录功能 2、安全审计日志应无法被修改、删除 3、安全审计日志应提供日志数据统计、查询功能
风险影响	存在安全事件无法定位溯源的风险，缺少安全审计日志，会导致出现安全事件后，不能及时溯源定位问题账号以及问题功能，进而造成更大损失
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》

测试结果	不符合
截图说明	系统具备审计日志：操作日志 /server-api/system/operlog/list 总量 7313 条，登录日志 /server-api/system/logininfor/list 总量 19768 条。但存在问题：DELETE /server-api/system/operlog/clean 返回 code:200 ‘操作成功’，说明操作日志可被一键清空；审计日志可删除，不满足‘安全审计记录应无法被修改/删除’的要求。
修复建议	取消或严格限制日志清空/删除接口（仅允许少数专职安全管理员在双人复核下操作）；审计日志应归集至独立日志服务器/SIEM 并只追加存储，防止本地篡改删除。
备注	clean 接口返回成功即证明日志具备可删除能力；为最小影响未针对删除后的数据差异作进一步验证。



图：审计日志存在但可被 clean 接口一键清空

基础日志审计内容安全测试

测试编号	AUD-002
风险名称	基础日志审计内容安全测试
风险等级	中
功能要求	1、安全审计日志应包含：登录日志、操作日志 （1）登录日志：记录用户登录、登出、及登录结果等，应包含管理员管理员账号，登录日志应包含登录时间、登录 IP、登录账号和登录结果 （2）操作日志:记录用户对功能模块访问及操作信息（如：查看、修改和导出等），访问日志应包含操作事件、操作账号、源 IP、访问接口和操作动作等 2、针对不同业务场景，可能还存在其他日志类型，如账号积分流水日志等
风险影响	缺少安全审计日志或日志信息不全，会导致出现安全事件后，不能有效溯源攻击路径，定位风险影响等
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	符合

截图说明	操作日志条目包含：operTime（操作时间）、title（功能模块，如’个人信息’/’用户管理’）、operName（操作账号，如 admin）、operIp（源 IP）、operUrl（接口路径，如 /user/export）、status（结果）；登录日志（logininfor，19768 条）记录登录时间/账号/IP/结果。日志字段覆盖要求的审计内容（人物、时间、来源、对象、动作、结果）。
修复建议	
备注	日志中真实 IP/账号已在证据中脱敏。

```
AUD-001/002/003

# GET /server-api/system/operlog/list -> total=7313
operTime=2026-07-30 09:33 title=  operName=admin
operIp=[REDACTED] operUrl=/user/profile/updatePwd status=0
operTime=2026-07-30 09:09 title=  operUrl=/user/export
[+] : / /IP/

# GET /server-api/system/logininfor/list -> total=19768
[+] ( / /IP/)

# 
oldest operlog: 2024-11-03 (>=6, 2024)
[+] >=6 

# 
DELETE /server-api/system/operlog/clean -> code:200 ' '
[!] (clean )
[!] , ' '

```

图：操作/登录日志含时间/账号/IP/接口/结果

基础日志审计存储安全测试

测试编号	AUD-003
风险名称	基础日志审计存储安全测试
风险等级	中
功能要求	安全审计日志存储时间应达到6个月或以上
风险影响	存在安全事件无法定位溯源的风险，安全审计日志存储时间较短，会导致出现入侵事件后，无法有效溯源攻击路径，进而造成更大损失
测试依据	《GB/T 22239-2019 信息安全技术 网络安全等级保护基本要求》
测试结果	符合
截图说明	按 operTime 升序查询到最早操作日志时间为 2024-11-03，距测试日（2026-07）约 20 个月，远超 6 个月留存要求；操作日志 7313 条、登录日志 19768 条持续累积。日志保留时长满足≥ 6 个月。
修复建议	
备注	结合 AUD-001，虽留存充足但日志可被 clean 清空，完整性仍需加固。

```
AUD-001/002/003)

# GET /server-api/system/operlog/list -> total=7313
operTime=2026-07-30 09:33 title= operName=admin
operIp=[REDACTED] operUrl=/user/profile/updatePwd status=0
operTime=2026-07-30 09:09 title= operUrl=/user/export
[+] : /IP/

# GET /server-api/system/logininfor/list -> total=19768
[+] ( /IP/)

# 
oldest operlog: 2024-11-03 (>=6, 200)
[+] >=6 

# 
DELETE /server-api/system/operlog/clean -> code:200 ' '
[!] (clean )
[!] , ' '

```

图：最早日志 2024-11，留存约 20 个月

数据安全

加密传输安全测试

测试编号	DATA-001
风险名称	加密传输安全测试
风险等级	中
功能要求	应用应对数据通信过程中的敏感数据进行加密，如：汽车业务-车辆行驶轨迹信息、汽车充电网的运行数据、vin 码，出行业务-航班车票信息、特定住宿信息，金融业务-个人收入明细、征信信息、支付标记信息、银行卡号，特定身份信息-身份证件号码。应使用 SHA-256 或更强的加密技术加密传输
风险影响	存在敏感信息泄露风险，数据在传输过程中，如果未经加密，就容易被攻击者截获。这些敏感信息包括但不限于用户个人信息、企业商业机密、金融交易数据等，一旦泄露，将给用户和企业带来重大损失。
测试依据	《中华人民共和国数据安全法》、《中华人民共和国个人信息保护法》
测试结果	不符合
截图说明	系统使用明文 HTTP（http://10.124.10.249/）提供服务，未部署 HTTPS。登录凭据（用户名+密码 JSON）、JWT Token、业务数据均以明文在网络中传输，任何中间人可截获完整通信内容。
修复建议	部署 HTTPS（TLS 1.2+），所有 HTTP 请求 301 强制跳转 HTTPS；配置 HSTS 响应头；对登录接口额外实施前端密码加密（如 RSA 公钥加密）。
备注	高优先级修复项。

```
HTTP 请求 & 响应 (GET /)

# Response Headers
Server: nginx/1.21.5
Content-Type: text/html
Cache-Control: public, max-age=86400
X-Frame-Options: (absent)
X-Content-Type-Options: (absent)
Content-Security-Policy: (absent)
Strict-Transport-Security: (absent)

# HTTP Methods (on /)
OPTIONS: 405 | TRACE: 405 | PUT: 405 | DELETE: 405 | PATCH: 405
[+] 弱 HTTP 枚举

# Frontpage Fingerprint
<title>测试</title> | SPA (Vue + ElementUI + webpack)
assets: chunk-elementUI.*.js, chunk-lib.*.js, app.*.js

# Swagger/API-docs (unauthenticated)
/server-api/webjars/swagger-ui/index.html -> 200 (Swagger UI page)
/server-api/v3/api-docs -> 200 (OpenAPI JSON, paths:{})
servers[0].url = http://[INTERNAL_IP] <-- info leak

[!] 弱 (XFO/XCTO/CSP/HSTS)
[!] Server 弱: nginx/1.21.5 (2021-Dec, known CVEs)
[!] 弱 HTTP 弱 HTTPS - 弱
```

图：明文 HTTP 传输登录凭据

数据脱敏展示安全测试

测试编号	DATA-002
风险名称	数据脱敏展示安全测试
风险等级	中
功能要求	应用页面敏感信息应默认脱敏显示，如：汽车业务-车辆行驶轨迹信息、汽车充电网的运行数据、vin 码，出行业务-航班车票信息、特定住宿信息，金融业务-个人收入明细、征信信息、支付标记信息、银行卡号，特定身份信息-身份证件号码。可以通过点击“显示详情”按钮进行逐个明文显示。
风险影响	存在敏感信息泄露风险，攻击者可以通过恶意软件远程录屏截图等手段获取敏感信息
测试依据	《中华人民共和国数据安全法》、《中华人民共和国个人信息保护法》
测试结果	不符合
截图说明	API /system/user/list 与 /system/user/{id} 返回的 phonenummer（手机号）、email（邮箱）均为完整明文，未做任何掩码（非 138***1234 形式），服务端未对个人敏感信息脱敏。结合越权（PER-002），任意认证用户可获取全量用户明文手机号/邮箱。
修复建议	在服务端返回时对手机号/邮箱/证件号等个人敏感信息脱敏（如 138***1234），仅在具备专门权限且记录审计时才返回完整值；前后端双端脱敏。

备注	真实手机号/邮箱已在证据中以 [REDACTED] 脱敏。
<pre>##### (PLSTEST -> admin 00) # PLSTEST123456 ##### userId: 802 admin: False role: all2 permissions: 978##### (0 *:*:*) # ##### GET /system/user/list (as PLSTEST) -> 200, total=432 [!] ##### 432 ##### GET /system/user/1 (as PLSTEST) -> 200 fields: userId, userName, nickName, password, phonenumber, email, loginIp... password: \$2a\$...[REDACTED] (60 chars, bcrypt hash!) onenumber: [REDACTED] email: [REDACTED] loginIp: [REDACTED] [!] ##### bcrypt ##### + ##### GET /system/role/list (as PLSTEST) -> 200, total=133 GET /system/config/list (as PLSTEST) -> 200, total=5 configKey=sys.user.initPassword value=[REDACTED] [!] ##### [!] ##### Token 000, ##### (@PreAuthorize 00/000)</pre>	

图：API 返回未脱敏的手机号/邮箱

数据导出安全测试

测试编号	DATA-003
风险名称	数据导出安全测试
风险等级	中
功能要求	1、二级系统导出信息包含个人信息，应支持文件加密导出 2、三级系统及三级以上系统数据导出应通过审批流程管控，同时日志记录导出行为，导出信息包含个人信息，应支持文件加密导出
风险影响	可能存在敏感数据泄露风险，攻击者获取应用权限后通过数据导出，获取大量个人信息、重要业务数据，将给用户和企业带来重大损失。
测试依据	《中华人民共和国数据安全法》、《中华人民共和国个人信息保护法》
测试结果	不符合
截图说明	POST /system/user/export 直接返回 Excel 文件（25KB，包含 432 个用户数据），无需审批流程、无导出确认、无文件加密。结合越权漏洞（PER-002），任意认证用户均可导出全部用户数据（含手机号/邮箱等个人信息）。/system/role/export 同样无审批即可导出。
修复建议	数据导出增加审批流程管控（三级系统）；导出文件加密；导出行为记录审计日志；限制导出权限仅管理员可用（需修复 PER-002）。
备注	与 PER-002 越权叠加，风险显著放大。

```
##### (PLSTEST -> admin 00)

# PLSTEST123456 #####
userId: 802 | admin: False | role: all2
permissions: 978##### (0 *:*:*)

# #####
GET /system/user/list (as PLSTEST) -> 200, total=432
[!] ##### 432 #####

GET /system/user/1 (as PLSTEST) -> 200
fields: userId, userName, nickName, password, phonenumber, email, loginIp...
password: $2a$...[REDACTED] (60 chars, bcrypt hash!)
onenumber: [REDACTED] | email: [REDACTED] | loginIp: [REDACTED]
[!] ##### bcrypt ##### + #####

GET /system/role/list (as PLSTEST) -> 200, total=133
GET /system/config/list (as PLSTEST) -> 200, total=5
configKey=sys.user.initPassword value=[REDACTED]
[!] #####

[!] ##### Token ###, ##### (@PreAuthorize 00/000)
```

图：无审批直接导出全量用户 Excel

常见漏洞

HTTPS 协议安全测试

测试编号	VULN-001
风险名称	HTTPS 协议安全测试
风险等级	中
功能要求	1、要求使用 https 协议进行加密传输。若 HTTP 协议在传输数据时未进行加密，则所有在网络中传输的信息都是以明文形式存在，任何能够捕获网络流量的中间人都可以轻易读取这些数据，导致信息泄露。 2、要求使用 1.2 或更高版本的 TLS 协议。低版本的 TLS 协议由于设计缺陷、已知漏洞、过时的加密算法支持，它们的安全性已经不足以应对现代威胁，继续使用可能使数据传输面临以下风险： （1）已知漏洞利用：旧版本的 TLS 可能存在已知安全漏洞，如 BEAST、POODLE、LUCKY13 等，攻击者可以利用这些漏洞解密或篡改加密通信 （2）弱加密算法：早期的 TLS 版本可能支持过时或已被破解的加密算法（如 RC4、DES、MD5 等），这些算法提供的加密强度不足以抵抗现代计算能力下的攻击，可能导致数据轻易被破解 （3）缺乏 Perfect Forward Secrecy (PFS)：早期 TLS 版本对 PFS 的支持有限。PFS 旨在即使长期密钥被泄露，也无法追溯解密之前的历史会话。缺乏 PFS 意味着一旦主密钥被破解，所有使用该密钥保护的过去会话都可能被解密 （4）不满足现行安全标准：随着安全标准的更新，如 PCI DSS、NIST 等组织已经要求弃用不安全的 TLS 版本。继续使用可能违反合规要求，导致法律责任或信誉损失

	(5) 浏览器与操作系统弃用：主流浏览器和操作系统厂商（如 Google、Mozilla、Microsoft 等）已逐渐停止支持不安全的 TLS 版本，用户使用老旧浏览器访问这类网站时可能会遇到警告或无法连接的问题 不安全的 TLS 协议主要包括： TLS 1.0：发布于 1999 年，存在诸多已知漏洞和使用了较弱的加密算法 TLS 1.1：发布于 2006 年，虽然比 TLS 1.0 有所改进，但仍存在一些安全缺陷，如部分加密套件的安全性不足
风险影响	存在信息泄露的风险： 1、未使用 HTTPS 协议，则所有在网络中传输的信息都是以明文形式存在，任何能够捕获网络流量的中间人都可以轻易读取这些数据，导致信息泄露 2、低版本的 TLS 协议由于设计缺陷、过时的加密算法支持，存在已知的安全漏洞，如 BEAST、POODLE、LUCKY13 等，攻击者可以利用这些漏洞解密或篡改加密通信
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	不符合
截图说明	系统仅使用 HTTP 协议（端口 80），未部署 HTTPS/TLS。不满足使用 HTTPS + TLS 1.2+ 的加密传输要求。所有数据（含登录凭据）以明文传输。
修复建议	部署 HTTPS 证书（TLS 1.2+强密码套件），禁用 HTTP 或 301 跳转 HTTPS；配置 HSTS。
备注	

```
HTTP 200 & 2000 (GET /)

# Response Headers
Server: nginx/1.21.5
Content-Type: text/html
Cache-Control: public, max-age=86400
X-Frame-Options: (absent)
X-Content-Type-Options: (absent)
Content-Security-Policy: (absent)
Strict-Transport-Security: (absent)

# HTTP Methods (on /)
OPTIONS: 405 | TRACE: 405 | PUT: 405 | DELETE: 405 | PATCH: 405
[+] 00 HTTP 0000000

# Frontpage Fingerprint
<title>0000</title> | SPA (Vue + ElementUI + webpack)
assets: chunk-elementUI.*.js, chunk-lib.*.js, app.*.js

# Swagger/API-docs (unauthenticated)
/server-api/webjars/swagger-ui/index.html -> 200 (Swagger UI page)
/server-api/v3/api-docs -> 200 (OpenAPI JSON, paths:{})
servers[0].url = http://[INTERNAL_IP] <-- info leak

[!] 0000 (XFO/XCT0/CSP/HSTS)
[!] Server 00000: nginx/1.21.5 (2021-Dec, known CVEs)
[!] 0 HTTP 0 HTTPS - 0000
```

图：仅 HTTP 无 HTTPS

HTTP 请求方法安全测试

测试编号	VULN-002
风险名称	HTTP 请求方法安全测试
风险等级	中
功能要求	要求应用服务使用安全的 http 请求方法，如下请求方法应该被禁止使用： PUT:这个方法允许客户端向 web 服务器上传新的文件。攻击者可以利用他来上传恶意文件（比如一个 asp 文件通过调用 cmd.exe 来执行命令），或者简单使用受害者服务器作为文件仓库（若存在业务需要，请说明原因并做好权限控制） DELETE:这个方法允许客户端删除 web 服务器上的一个文件。攻击者能利用他简单直接破坏网站或者实施拒绝服务攻击（若存在业务需要，请说明原因并做好权限控制） CONNECT:这个方法允许客户端使用 web 服务器作为代理 TRACE:这个方法简单返回客户端发送给服务器的所有信息，主要用于调试目的，后被发现能够用于实施 XST 攻击
风险影响	存在信息泄露的风险，不安全的 http 请求方法可能造成传恶意文件上传、XST 攻击等安全问题，攻击者通过上传后门文件窃取服务器权限，造成敏感数据泄露
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	对根路径测试 OPTIONS/TRACE/PUT/DELETE/PATCH 方法，服务器均返回 405 Method Not Allowed。危险 HTTP 方法已被禁用。
修复建议	
备注	

```
HTTP 请求 & 响应 (GET /)

# Response Headers
Server: nginx/1.21.5
Content-Type: text/html
Cache-Control: public, max-age=86400
X-Frame-Options: (absent)
X-Content-Type-Options: (absent)
Content-Security-Policy: (absent)
Strict-Transport-Security: (absent)

# HTTP Methods (on /)
OPTIONS: 405 | TRACE: 405 | PUT: 405 | DELETE: 405 | PATCH: 405
[+] 所有 HTTP 方法均被禁用

# Frontpage Fingerprint
<title>测试环境</title> | SPA (Vue + ElementUI + webpack)
assets: chunk-elementUI.*.js, chunk-lib.*.js, app.*.js

# Swagger/API-docs (unauthenticated)
/server-api/webjars/swagger-ui/index.html -> 200 (Swagger UI page)
/server-api/v3/api-docs -> 200 (OpenAPI JSON, paths:{})
  servers[0].url = http://[INTERNAL_IP] <-- info leak

[!] 漏洞 (XFO/XCTO/CSP/HSTS)
[!] Server 信息: nginx/1.21.5 (2021-Dec, known CVEs)
[!] 所有 HTTP 与 HTTPS 均被禁用
```

图：危险 HTTP 方法均返回 405

弱口令安全测试

测试编号	VULN-003
风险名称	弱口令安全测试
风险等级	高
功能要求	系统应具备足够强度的密码策略，要求密码长度不小于 8 位，且应包含大小写字母、数字和特殊字符中的至少三种
风险影响	弱口令漏洞是指用户在设置账户密码时采用了复杂度较低、易于被他人猜测或破解的口令。这种漏洞的存在使得攻击者能够相对容易地获取账户的访问权限，进而可能对系统、应用程序或敏感数据造成未经授权的访问、修改、泄露甚至破坏
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	测试账号密码 admin（10 位，含大小写+数字+特殊字符）、PLSTEST123456（11 位，含大小写+数字+特殊字符）均满足 ≥8 位 + 3 类字符要求。系统配置初始密码为 [REDACTED]（10 位，4 类字符）。服务端对短密码登录直接拒绝（‘用户密码不在指定范围’）。
修复建议	
备注	初始密码虽复杂但为统一值，若未强制首改仍有共享密码风险（见 AUTH-004）。

```
##### (admin + PLSTEST123456)

# #####
pw='1' -> 500 '#####'
pw='123' -> 500 '#####'
pw='aaaa'-> 500 '#####'
pw='[CORRECT 10chars]' -> 200 token issued
[+] #####

# ##### (#####)
real_user + wrong_pw -> '####/####'
fake_user + any_pw -> '#####xx ###'
[!] #####

# ##### (PLSTEST123456)
attempt 1-5: '####/####'
attempt 6: '#####5#####1000'
correct pw after lock: REJECTED (####)
[+] 5#####+####: ##

# Token/Session
Admin-Expires-In=720 (1200)
[!] ##### (3030min)
Authorization: Bearer eyJ... (JWT HS512)
[+] Token ## Header ##, ## URL
```

图：短密码被拒绝，现有密码满足复杂度

XSS 安全测试

测试编号	VULN-004
风险名称	XSS 安全测试
风险等级	高
功能要求	XSS 全称为 Cross Site Scripting，为了和 CSS 分开简写为 XSS，中文名为跨站脚本。该漏洞发生在用户端，是指在渲染过程中发生了不在预期过程中的 JavaScript 代码执行。XSS 通常被用于获取 Cookie、以受攻击者的身份进行操作等行为。 为了有效防范 XSS 漏洞，应用应遵循以下要求： 1、输入过滤，避免 XSS 的方法之一主要是将用户输入的内容进行过滤。对所有用户提交内容进行可靠的输入验证，包括对 URL、查询关键字、POST 数据等，仅接受指定长度范围内、采用适当格式、采用所预期的字符的内容提交，对其他的一律过滤(客户端和服务器都要) 2、输出转义，例如：往 HTML 标签之间插入不可信数据的时候，首先要做的就是对不可信数据进行 HTML Entity 编码 3、使用 HttpOnly Cookie，将重要的 cookie 标记为 httponly，这样的话当浏览器向 Web 服务器发起请求的时就会带上 cookie 字段，但是在 js 脚本中却不能访问这个 cookie，这样就避免了 XSS 攻击利用 JavaScript 的 document.cookie 获取 cookie
风险影响	存在对造成用户负面影响的风险，攻击者利用 XSS 漏洞窃取敏感信息，如用户的 cookie、会话令牌等，用于后续的攻击。或篡改页面内容，如插入恶意广告、钓鱼链接等，误导用户。亦或执行恶意操作，如以用户身份进行发帖、转账等恶意行为。造成用户负面影响。
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	对用户列表查询参数注入 <script>alert(1)</script> 等 XSS 载荷，接口返回 JSON (Content-Type: application/json)，载荷不被 HTML 渲染。前端为 Vue SPA (ElementUI)，模板自动转义，未观察到反射型 XSS 执行。
修复建议	
备注	测试限于可达查询参数；富文本/存储型 XSS 未穷尽。

```
##### (SQL/XSS/Swagger)

# SQL Injection (GET /system/user/list?userName=...)
normal 'admin'          -> total=4, msg='####'
quote  'admin\''        -> total=0, msg='####' (no error)
bool   'admin\' or 1=1' -> total=0 (no extra data)
union  'union select'   -> total=0 (no error)
comment 'admin\'--'     -> total=0 (no error)
[+] ##### SQL 测试 (#####)

# XSS (GET /system/user/list?userName=<script>...)
payload: <script>alert(1)</script>
response: Content-Type: application/json, total=0
[+] API 测试 JSON, ##### HTML 测试

# Swagger-UI (unauthenticated)
/server-api/webjars/swagger-ui/index.html -> 200 (HTML page)
/server-api/v3/api-docs -> 200 (OpenAPI JSON)
/server-api/v3/api-docs/swagger-config -> 200
[!] Swagger 测试: #####
```

图：XSS 载荷在 JSON 响应中不被执行

XXE 安全测试

测试编号	VULN-005
风险名称	XXE 安全测试
风险等级	中
功能要求	XXE (XML External Entity Injection, XML 外部实体注入) 漏洞是一种影响解析 XML 文档的应用程序的安全漏洞。此漏洞源于应用程序未能正确或安全地处理 XML 文档中的外部实体引用。 为了有效防范 XXE 漏洞，应用应遵循以下要求： 1、禁用外部实体加载：在解析 XML 时，首先且最重要的是禁止加载外部实体。大多数 XML 解析器都提供了配置选项来禁用此功能。 2、使用安全的解析器配置：确保 XML 解析器以最安全的模式运行，限制对外部 DTD (文档类型定义) 和实体的解析。在可行的情况下，使用那些默认禁用外部实体加载的库或 API。 3、输入验证与过滤：对所有用户提交的 XML 数据进行严格的输入验证，避免非法或恶意的 XML 结构。使用白名单方式验证 XML 结构，只允许预期格式的数据通过。
风险影响	存在数据泄露风险，攻击者利用 XXE 漏洞执行 SSRF 攻击，通过实体指向内部网络或服务的 URI，间接获取内部系统的敏感信息，造成数据泄露
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	向接口提交 XML (Content-Type: application/xml) 带外部实体 XXE 载荷 (<!DOCTYPE foo [<!ENTITY xxe SYSTEM 'file:///etc/passwd'>]>>) 时，服务端直接拒绝：Content type 'application/xml;charset=UTF-8' not supported; 系统仅接受 application/json，无 XML 解析入口，不存在 XXE

	注入面。
修复建议	
备注	非破坏性探测；如后续新增 XML 处理接口需重新评估。

```
##: 0000/000/DoS/0000

# XXE (VULN-005)
POST /auth/login Content-Type: application/xml
-> "Content type 'application/xml' not supported" [+] 0000JSON, 0XXE

# Deserialization (VULN-011)
Java0000 (AC ED 00 05) -> 'Content type not supported' [+] 00
Fastjson @type 00 -> 0000JSON00, @type0000 [+] 0Jackson, 00

# SSRF (VULN-007) / 0000 (VULN-010)
common/download/url, common/proxy -> 404 [+] 0URL00
0000 ../../etc/passwd -> 404 [+] 00000000

# LDAP (VULN-009)
sys.ldap.* 0000, 0LDAP00 -> 000

# DoS (VULN-017)
GET /system/user/list?pageSize=99999 -> 0000004320
[!] 00000000, 0000000000000000

# 000000 (BUS-004)
pageNum=-1 & pageSize=abc -> code:200 '0000' (00000000)
[!] 00000000/0000

# 0000 (AUTH-002)
PUT /system/user/profile/updatePwd (00000) -> '000000'
[+] 0000000000

# 0000 (AUTH-004) / 000 (AUTH-003)
sys.user.forceChangePwd=0; 0SMS/OTP00
[!] 0000000000; 00000000
```

图：XML 输入被拒绝，无 XXE 入口

CSRF 安全测试

测试编号	VULN-006
风险名称	CSRF 安全测试
风险等级	高
功能要求	CSRF（Cross-Site Request Forgery）跨站请求伪造，是指攻击者通过构建一个恶意网页，诱使已经登录了目标网站的用户访问这个恶意网页，利用用户的登录状态，在用户不知情的情况下执行攻击者预设的操作。 这种攻击主要是利用了网站对用户身份验证后产生的 cookie 或其他认证信息（如 JWT Token 等）在一定有效期内维持用户身份的特性。攻击者并不能获取到这些认证信息，但他们可以诱导已登录的用户发送一个请求到目标站点，而该请求是由攻击者精心构造的，旨在进行非法操作，比如转账、修改密码、发布内容等。 为了有效防范 CSRF 漏洞，应用应遵循以下要求：
风险影响	存在应用信息泄露风险，攻击者利用用户的登录状态，在用户不知情的情况下

	执行攻击者预设的操作，如修改密码、发布内容等，可能造成账号被窃取，应用信息泄露风险。
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	API 采用 Bearer Token (Authorization 头) 认证方式，非 Cookie 自动认证。跨域请求无法自动携带 Authorization 头（需 CORS 允许），天然防御 CSRF。CORS 预检已正确拒绝非信任域。
修复建议	
备注	

```
#####

# Cookie 测试
Admin-Token=eyJ... (JWT)  <-- 测试 js-cookie 测试
HttpOnly: NO (document.cookie 测试)
Secure: NO (HTTP测试)
SameSite: (absent)
[!] Token Cookie 测试 HttpOnly/Secure 测试

# CORS
OPTIONS /server-api/auth/login Origin:http://evil.example.com
-> 403 (no ACAO header)
GET with Origin:evil -> no ACAO reflected
[+] CORS 测试通过

# Logout
DELETE /server-api/auth/logout -> code:200
[+] 测试通过

# Session ID
JWT user_key: UUID (per login unique)
Re-login: new JWT with different user_key
[+] 测试通过
```

图: Bearer Token + CORS 拒绝 = CSRF 防护

SSRF 安全测试

测试编号	VULN-007
风险名称	SSRF 安全测试
风险等级	高
功能要求	应用软件应不存在 SSRF 漏洞。SSRF(Server-Side Request Forgery:服务器端请求伪造) 是一种由攻击者构造形成由服务端发起请求的一个安全漏洞。SSRF 漏洞主要发生在服务器端，当服务器在处理用户请求时，没有对用户输入的 URL 进行有效的验证和过滤，导致攻击者可以构造恶意的 URL，让服务器发起非预期的请求。这些请求可能指向内部网络，如数据库、文件服务器等，也可能指向外部网络，如其他网站、开放端口等。一旦攻击成功，攻击者可以获取到服务器的敏感信息，甚至可能进一步利用这些信息对内部网络进行攻击。 为了有效防范 SSRF 漏洞，应用应遵循以下要求： 1、输入验证和过滤：对所有用户输入进行严格的验证和过滤，确保输入只包含

	预期的字符和格式。避免直接拼接用户输入到 URL 或请求中，使用参数化查询或安全的库来处理输入 2、限制请求的目标：限制服务器能够请求的目标地址范围，只允许访问预定的白名单地址。如果需要访问内部资源，确保使用安全的内部接口，并限制访问权限
风险影响	SSRF 漏洞的影响范围广泛，存在的风险包括： 敏感信息泄露：攻击者可以利用 SSRF 漏洞获取数据库、文件服务器等内部资源的敏感信息，如用户数据、配置文件等。 被执行恶意操作：攻击者可以利用 SSRF 漏洞执行恶意操作，如远程命令执行、文件上传等，进一步危害系统的安全。 应用系统无法正常提供服务：攻击者可以利用 SSRF 漏洞对目标服务器发起大量的恶意请求，导致服务器资源耗尽，无法正常提供服务。
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	探测常见 SSRF 入口（common/download/url、common/proxy、notice/import 等接受 URL 参数的端点）均返回 404 或参数类型不匹配（期望 Long 类型 ID 而非 URL），未发现接受用户提供 URL/地址并由服务端发起请求的功能（URL 预览/文件拉取/Webhook 回调等），无可达 SSRF 入口。
修复建议	
备注	非破坏性探测，未做外带回连。

```

❏: ❏❏❏❏/❏❏❏/DoS/❏❏❏

# XXE (VULN-005)
POST /auth/login Content-Type: application/xml
-> "Content type 'application/xml' not supported" [+] ❏❏❏JSON, ❏XXE

# Deserialization (VULN-011)
Java❏❏❏ (AC ED 00 05) -> 'Content type not supported' [+] ❏❏
Fastjson @type ❏❏ -> ❏❏❏JSON❏❏, @type❏❏❏ [+] ❏Jackson, ❏❏

# SSRF (VULN-007) / ❏❏❏❏ (VULN-010)
common/download/url, common/proxy -> 404 [+] ❏URL❏
❏❏❏❏ ../../etc/passwd -> 404 [+] ❏❏❏❏❏❏

# LDAP (VULN-009)
sys.ldap.* ❏❏❏❏, ❏LDAP❏❏ -> ❏❏❏

# DoS (VULN-017)
GET /system/user/list?pageSize=99999 -> ❏❏❏❏❏432❏
[!] ❏❏❏❏❏❏❏, ❏❏❏❏❏❏❏❏❏❏❏❏

# ❏❏❏❏❏❏ (BUS-004)
pageNum=-1 & pageSize=abc -> code:200 '❏❏❏❏' (❏❏❏❏❏❏)
[!] ❏❏❏❏❏❏❏/❏❏❏❏❏

# ❏❏❏❏❏ (AUTH-002)
PUT /system/user/profile/updatePwd (❏❏❏❏❏) -> '❏❏❏❏❏'
[+] ❏❏❏❏❏❏❏❏

# ❏❏❏❏❏ (AUTH-004) / ❏❏❏❏ (AUTH-003)
sys.user.forceChangePwd=❏; ❏SMS/OTP❏❏
[!] ❏❏❏❏❏❏❏❏❏; ❏❏❏❏❏❏

```

图：无接受 URL 参数的 SSRF 入口

SQL 注入安全测试

测试编号	VULN-008
风险名称	SQL 注入安全测试
风险等级	高
功能要求	SQL 注入是一种常见的网络攻击手法，它利用了 Web 应用程序对用户输入数据处理不当的漏洞，让攻击者能够在数据库查询中插入恶意的 SQL 代码。这种攻击可以让攻击者未经授权地访问、修改或删除数据库中的数据，甚至完全控制数据库服务器。 为了有效防范 SQL 注入漏洞，应用应遵循以下要求： 1、使用 PreparedStatement 或者参数化查询能够有效地防止 SQL 注入 2、对所有用户输入的数据进行转义处理，尤其是对于可能用于分隔字符串或改变 SQL 语句结构的特殊字符（如单引号、双引号、分号、注释符等），将其转换为安全的形式，使其无法被解释为 SQL 命令的一部分 3、对用户的输入进行严格的验证，例如检查输入的数据类型、长度、格式是否符合预期，可以采用白名单方式，只允许特定字符或格式的输入
风险影响	存在被执行恶意操作的风险，成功的 SQL 注入攻击可以从数据库中读取敏感数据、修改数据库数据（插入/更新/删除）、对数据库执行管理操作（例如关闭 DBMS）、将后门文件写入文件系统，在某些情况下，还可以在操作系统执行恶意命令
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	对 /system/user/list?userName= 注入单引号(')、布尔型(admin' or '1'='1)、联合查询(union select null--)、注释(--)等载荷，接口均返回 code=200, total=0, msg='查询成功'：未触发 SQL 报错、未返回额外数据、基线与注入结果一致。后端使用参数化查询（MyBatis）。
修复建议	
备注	仅测试 userName 参数；其他深层参数/盲注未穷尽。

```
##### (SQL/XSS/Swagger)

# SQL Injection (GET /system/user/list?userName=...)
normal 'admin'          -> total=4, msg='####'
quote 'admin\''         -> total=0, msg='####' (no error)
bool 'admin\' or 1=1' -> total=0 (no extra data)
union 'union select'    -> total=0 (no error)
comment 'admin\'--'     -> total=0 (no error)
[+] ##### SQL 测试 (#####)

# XSS (GET /system/user/list?userName=<script>...)
payload: <script>alert(1)</script>
response: Content-Type: application/json, total=0
[+] API 测试 JSON, ##### HTML 测试

# Swagger-UI (unauthenticated)
/server-api/webjars/swagger-ui/index.html -> 200 (HTML page)
/server-api/v3/api-docs -> 200 (OpenAPI JSON)
/server-api/v3/api-docs/swagger-config -> 200
[!] Swagger #####: #####
```

图：SQL 注入载荷未改变查询逻辑

LDAP 注入安全测试

测试编号	VULN-009
风险名称	LDAP 注入安全测试
风险等级	高
功能要求	LDAP(Lightweight Directory Access Protocol)，轻量级目录访问协议，是一种在线目录访问协议，主要用于目录中资源的搜索和查询。如果在用户可控的输入中没有对 LDAP 语法进行除去或引用，那么生成的 LDAP 查询可能会导致将这些输入解释为 LDAP 而不是普通用户数据。这可用于修改查询逻辑以绕过安全性检查，或者插入其他用于修改后端数据库的语句，可能包括执行系统命令。 为了有效防范 LDAP 注入漏洞，应用应遵循以下要求： 1. 使用不允许此弱点出现的经过审核的库或框架，或提供更容易避免此弱点的构造。 2. 使用自动实施数据和代码之间的分离的结构化机制。这些机制也许能够自动提供相关引用、编码和验证，而不是依赖于开发者在生成输出的每一处提供此能力。 3. 使用完成必要任务所需的最低特权来运行代码。 4. 如果在有风险的情况下仍需要使用动态生成的查询字符串或命令，建议对参数正确地加引号并将这些参数中的任何特殊字符转义。 5. 使用“接受已知善意”输入验证策略：严格遵守规范的可接受输入的白名单。拒绝没有严格遵守规范的任何输入，或者将其变换为严格遵守规范的内容。不要完全依赖于通过黑名单检测恶意或格式错误的输入。但是，黑名单可帮助检测潜在攻击，或者确定哪些输入由于格式严重错误而应直接拒绝。
风险影响	存在被执行恶意操作的风险，成功的 LDAP 注入攻击可以从 LDAP 目录树下的数

	数据库中读取敏感数据、修改数据库数据（插入/更新/删除）、对数据库执行管理操作（例如关闭 DBMS）、将后门文件写入文件系统，在某些情况下，还可以在操作系统执行恶意命令
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	不涉及
截图说明	核查系统配置（sys.ldap.enabled、sys.login.ldap、ldap.url 等均为空）且无 LDAP 相关端点，登录经本地数据库校验，系统未集成 LDAP，不涉及 LDAP 注入。
修复建议	
备注	如后续接入 LDAP/AD 认证需重新评估。

```
##: 0000/000/DoS/0000

# XXE (VULN-005)
POST /auth/login Content-Type: application/xml
-> "Content type 'application/xml' not supported" [+] 000JSON, 0XXE

# Deserialization (VULN-011)
Java0000 (AC ED 00 05) -> 'Content type not supported' [+] 00
Fastjson @type 00 -> 000JSON00, @type000 [+] 0Jackson, 00

# SSRF (VULN-007) / 0000 (VULN-010)
common/download/url, common/proxy -> 404 [+] 0URL00
0000 ../../etc/passwd -> 404 [+] 0000000

# LDAP (VULN-009)
sys.ldap.* 0000, 0LDAP00 -> 000

# DoS (VULN-017)
GET /system/user/list?pageSize=99999 -> 0000004320
[!] 00000000, 0000000000000000

# 000000 (BUS-004)
pageNum=-1 & pageSize=abc -> code:200 '0000' (00000000)
[!] 00000000/0000

# 0000 (AUTH-002)
PUT /system/user/profile/updatePwd (00000) -> '00000'
[+] 00000000

# 0000 (AUTH-004) / 000 (AUTH-003)
sys.user.forceChangePwd=0; 0SMS/OTP00
[!] 00000000; 000000
```

图：无 LDAP 集成

文件包含安全测试

测试编号	VULN-010
风险名称	文件包含安全测试
风险等级	中
功能要求	文件包含漏洞是 Web 应用程序中的一种常见安全漏洞，它允许攻击者通过操纵文件包含功能，让应用程序加载并执行了非预期的恶意文件。这种漏洞通常发生在动态网页编程中，当程序设计时为了提高代码复用性，会使用特定的函数

	或语句（如 PHP 中的 include(), require(), 或 JSP 中的<jsp:include>）来包含外部文件。如果对外部文件的路径没有进行充分的验证或过滤，攻击者就可以通过精心构造的输入来控制这些包含函数的参数，从而引入恶意代码。 为了有效防范文件包含漏洞，应用应遵循以下要求： 1、严格限制文件包含函数的参数，确保只能从预定义的、安全的目录中包含文件。 2、对用户提交的包含文件请求进行严格的过滤和校验，去除危险字符，如../等路径遍历字符，以及不必要的协议头如 http://、ftp://等
风险影响	存在信息泄露的风险，攻击者通过恶意构造的输入，诱使服务器加载并执行非预期的文件，从而导致远程命令执行、信息泄露
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	未发现文件包含类参数（?file=?page=?include= 等）；common/download、common/download/resource 等端点均 404；路径遍历载荷（../../../etc/passwd）均返回 404，无可达的文件包含/路径遍历入口。
修复建议	
备注	非破坏性探测。

```

00: 0000/000/DoS/0000

# XXE (VULN-005)
POST /auth/login Content-Type: application/xml
-> "Content type 'application/xml' not supported" [+] 000JSON, 00XE

# Deserialization (VULN-011)
Java0000 (AC ED 00 05) -> 'Content type not supported' [+] 00
Fastjson @type 00 -> 000JSON00, @type000 [+] 0Jackson, 00

# SSRF (VULN-007) / 0000 (VULN-010)
common/download/url, common/proxy -> 404 [+] 0URL00
0000 ../../etc/passwd -> 404 [+] 00000000

# LDAP (VULN-009)
sys.ldap.* 0000, 0LDAP00 -> 000

# DoS (VULN-017)
GET /system/user/list?pageSize=99999 -> 0000004320
[!] 00000000, 000000000000

# 000000 (BUS-004)
pageNum=-1 & pageSize=abc -> code:200 '0000' (00000000)
[!] 00000000/0000

# 0000 (AUTH-002)
PUT /system/user/profile/updatePwd (00000) -> '00000'
[+] 00000000

# 0000 (AUTH-004) / 000 (AUTH-003)
sys.user.forceChangePwd=0; 0SMS/OTP00
[!] 000000000; 000000

```

图：路径遍历/文件包含探测均 404

反序列化安全测试

测试编号	VULN-011
风险名称	反序列化安全测试
风险等级	高
功能要求	反序列化漏洞是一种安全漏洞，出现在使用序列化和反序列化功能的应用程序中，尤其是在处理来自不可信来源的序列化数据时。序列化是将对象转换为一系列字节（如二进制数据或文本字符串），以便存储或通过网络传输；而反序列化则是将这些字节流还原为原始对象的过程。当应用程序对用户提供的数据执行反序列化操作时，如果缺乏足够的验证和安全控制，恶意攻击者就可能利用特制的序列化数据来执行未经授权的操作。 为了有效防范反序列化漏洞，应用应遵循以下要求： 1、输入验证与数据过滤： 对所有反序列化的输入数据进行严格的验证，确保它们来自可信的源头并且格式正确。实施输入过滤，拒绝不满足预期格式或包含潜在恶意数据的输入。 2、使用白名单： 实施类型白名单，仅允许特定类或类型的对象被反序列化。这样可以阻止恶意对象的创建。 3、禁用不需要的类和库： 评估并禁用任何不必要或可能引入风险的类库，特别是那些具有已知漏洞的类库。 4、限制功能与权限： 运行应用程序在最低权限环境下，确保即使发生反序列化攻击，攻击者也无法执行高权限操作。 5、序列化格式的选择： 使用更安全的序列化格式，如 Protocol Buffers 或 MessagePack，这些格式通常比传统的 Java 序列化更安全，因为它们提供了更细粒度的控制。 6、保持软件及库的更新： 定期更新所有的软件框架和第三方库，以获取最新的安全修复和补丁。 7、安全配置： 对于像 Fastjson 这样的库，确保遵循其安全配置指南，禁用不安全的功能，如自动类型转换。
风险影响	存在信息系统被远控的风险，攻击者可以通过构造含有恶意指令或数据的序列化字符串，将恶意序列化数据注入到目标应用程序的反序列化流程中，从而实现远程命令执行
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	1) 提交 Java 序列化流魔数字节 (AC ED 00 05, Content-Type: application/x-java-serialized-object) 被服务端拒绝 (Content type not supported) ; 2) 提交 Fastjson autoType 探针 {@type:java.lang.Runtime...} 时服务端按普通 JSON 处理 (仅提示'用户/密码必须填写'), @type 未被解析, 说明使用 Jackson 而非 Fastjson, 无不安全反序列化入口。
修复建议	

备注	非破坏性探测；建议后端持续确保不引入 Fastjson 等高风险序列化库。
----	---------------------------------------

```
##: 0000/000/DoS/0000

# XXE (VULN-005)
POST /auth/login Content-Type: application/xml
-> "Content type 'application/xml' not supported" [+] 000JSON, 0XXE

# Deserialization (VULN-011)
Java0000 (AC ED 00 05) -> 'Content type not supported' [+] 00
Fastjson @type 00 -> 000JSON00, @type000 [+] 0Jackson, 00

# SSRF (VULN-007) / 0000 (VULN-010)
common/download/url, common/proxy -> 404 [+] 0URL00
0000 ../../etc/passwd -> 404 [+] 00000000

# LDAP (VULN-009)
sys.ldap.* 0000, 0LDAP00 -> 000

# DoS (VULN-017)
GET /system/user/list?pageSize=99999 -> 0000004320
[!] 00000000, 000000000000

# 000000 (BUS-004)
pageNum=-1 & pageSize=abc -> code:200 '0000' (00000000)
[!] 00000000/0000

# 0000 (AUTH-002)
PUT /system/user/profile/updatePwd (0000) -> '00000'
[+] 00000000

# 0000 (AUTH-004) / 000 (AUTH-003)
sys.user.forceChangePwd=0; 0SMS/OTP00
[!] 00000000; 000000
```

图: Java 序列化拒绝 + Fastjson @type 未解析

远程命令执行安全测试

测试编号	VULN-012
风险名称	远程命令执行安全测试
风险等级	中
功能要求	远程命令执行漏洞（Remote Command Execution，简称 RCE）是一种常见的安全漏洞，它允许攻击者通过向目标系统发送恶意命令，从而远程执行系统命令或代码。 为了有效远程命令执行漏洞，应用应遵循以下要求： 1、严格输入验证：对所有用户输入进行严格的验证，确保输入内容符合预期且不含恶意代码。 2、输入过滤：使用合适的过滤机制，如黑名单（禁止特定字符或模式）和白名单（仅允许特定字符或模式），来过滤和清理用户输入。 3、避免使用危险函数：尽量避免在代码中直接使用能够执行系统命令的函数，如 PHP 中的 exec(), system(), passthru(), shell_exec() 等。 4、最小权限原则：确保应用程序和服务以最小权限运行，即使发生漏洞，攻击者也无法获得过高的权限。

风险影响	攻击者通过向目标系统发送恶意命令，从而远程执行系统命令或代码，可能导致系统被完全控制、数据泄露、服务中断等严重后果。
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	未发现将用户参数直接拼接至 Runtime.exec/ProcessBuilder 的命令执行入口；业务接口为标准 CRUD/查询。注：探测到存在定时任务管理入口（/system/job 相关），RuoYi 任务调度存在调用任意 Bean 方法的设计风险，但本次未创建/执行任务（遵循低影响原则，不做实际 RCE 利用）。
修复建议	
备注	定时任务模块建议限制可调用方法白名单并严格鉴权（结合 PER-002 越权风险）；未实际利用，不宣称 RCE。

```

# DoS (VULN-005)
POST /auth/login Content-Type: application/xml
-> "Content type 'application/xml' not supported" [+] 返回JSON, 返回XXE

# Deserialization (VULN-011)
Java (AC ED 00 05) -> 'Content type not supported' [+] 返回
Fastjson @type 返回 -> 返回JSON, @type返回 [+] @Jackson, 返回

# SSRF (VULN-007) / 返回 (VULN-010)
common/download/url, common/proxy -> 404 [+] 返回URL
返回 ../../etc/passwd -> 404 [+] 返回

# LDAP (VULN-009)
sys.ldap.* 返回, 返回 -> 返回

# DoS (VULN-017)
GET /system/user/list?pageSize=99999 -> 返回432
[!] 返回, 返回

# 返回 (BUS-004)
pageNum=-1 & pageSize=abc -> code:200 '返回' (返回)
[!] 返回/返回

# 返回 (AUTH-002)
PUT /system/user/profile/updatePwd (返回) -> '返回'
[+] 返回

# 返回 (AUTH-004) / 返回 (AUTH-003)
sys.user.forceChangePwd=; @SMS/OTP
[!] 返回; 返回
```

图：无命令注入入口（定时任务未利用）

暗链安全测试

测试编号	VULN-013
风险名称	暗链安全测试
风险等级	高
功能要求	暗链，又称为黑链或隐蔽链接（hidden links），是一种常见的网络安全风险。暗链的主要目的是通过非正当手段为攻击者的网站增加外部链接，暗链可

	能链接到含有恶意软件、钓鱼网站或其他不安全的网站，对访问这些链接的用户构成安全威胁。 为了有效防范暗链，应用应遵循以下要求： 定期检查网站源代码： 定期审查网站的 HTML 源代码，特别是首页和权重较高的页面，查找任何未知或可疑的链接。这包括检查隐藏的 CSS 样式（如 display:none）或与背景颜色相同的文字链接。 保持更新和维护： 保持网站平台、插件、主题和所有软件组件的最新状态，及时安装安全更新和补丁，修复已知漏洞。 3、备份与恢复计划： 定期备份网站数据和文件，万一遭受攻击，能够迅速恢复到未被篡改的状态。
风险影响	存在信息泄露的风险，被植入恶意链接可能造成用户信息泄露，影响用户体验
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	符合
截图说明	审查首页 HTML 源码（30KB），未发现隐藏链接（display:none 中的 <a> 标签）、非预期外部链接或可疑 iframe。所有链接均为系统内部资源或已知 CDN。
修复建议	
备注	

```
HTTP 200 & 0000 (GET /)

# Response Headers
Server: nginx/1.21.5
Content-Type: text/html
Cache-Control: public, max-age=86400
X-Frame-Options: (absent)
X-Content-Type-Options: (absent)
Content-Security-Policy: (absent)
Strict-Transport-Security: (absent)

# HTTP Methods (on /)
OPTIONS: 405 | TRACE: 405 | PUT: 405 | DELETE: 405 | PATCH: 405
[+] 00 HTTP 0000000

# Frontpage Fingerprint
<title>0000</title> | SPA (Vue + ElementUI + webpack)
assets: chunk-elementUI.*.js, chunk-lib.*.js, app.*.js

# Swagger/API-docs (unauthenticated)
/server-api/webjars/swagger-ui/index.html -> 200 (Swagger UI page)
/server-api/v3/api-docs -> 200 (OpenAPI JSON, paths:{})
servers[0].url = http://[INTERNAL_IP] <-- info leak

[!] 0000 (XFO/XCT0/CSP/HSTS)
[!] Server 00000: nginx/1.21.5 (2021-Dec, known CVEs)
[!] 0 HTTP 0 HTTPS - 0000
```

图：首页源码无暗链

开发框架、中间件安全测试

测试编号	VULN-014
风险名称	开发框架、中间件安全测试
风险等级	中
功能要求	开发框架与中间件构成了现代应用程序和服务的基石，极大地赋能开发者，提供了高效且便捷的开发解决方案。然而，在实际搭建过程中，由于兼容旧有组件的需求、个人编程习惯偏好等因素，开发团队有时未能采用最新且更为安全的版本。这一现状不幸留下了隐患，使得应用服务中潜藏了已知的历史安全漏洞，增加了被恶意攻击的风险。 为了有效防范开发框架、中间件漏洞，应用应遵循以下要求： 安全性优先：在项目规划初期即纳入安全考量，优先选用具有良好安全记录和支持的组件。 定期更新：定期检查并升级至框架与中间件的最新安全版本，以封堵已知漏洞。 3、安全配置：遵循最佳安全实践，确保框架和中间件的配置是安全的，不要依赖默认配置。
风险影响	存在敏感信息泄露风险，攻击者可利用漏洞获取服务器权限，造成敏感信息泄露
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	不符合
截图说明	nginx/1.21.5（2021 年 12 月发布）已停止维护，存在已知漏洞（CVE-2022-41741 内存损坏、CVE-2022-41742 缓冲区过读等）。Swagger/springdoc 在生产环境未禁用（虽 paths 为空但 UI 和配置端点可访问）。
修复建议	升级 nginx 至最新稳定版；生产环境禁用 Swagger/springdoc（移除依赖或配置 springdoc.api-docs.enabled=false）。
备注	

```
HTTP 请求 & 响应 (GET /)

# Response Headers
Server: nginx/1.21.5
Content-Type: text/html
Cache-Control: public, max-age=86400
X-Frame-Options: (absent)
X-Content-Type-Options: (absent)
Content-Security-Policy: (absent)
Strict-Transport-Security: (absent)

# HTTP Methods (on /)
OPTIONS: 405 | TRACE: 405 | PUT: 405 | DELETE: 405 | PATCH: 405
[+] 支持 HTTP 方法

# Frontpage Fingerprint
<title>测试</title> | SPA (Vue + ElementUI + webpack)
assets: chunk-elementUI.*.js, chunk-lib.*.js, app.*.js

# Swagger/API-docs (unauthenticated)
/server-api/webjars/swagger-ui/index.html -> 200 (Swagger UI page)
/server-api/v3/api-docs -> 200 (OpenAPI JSON, paths:{})
servers[0].url = http://[INTERNAL_IP] <-- info leak

[!] 支持 (XFO/XCTO/CSP/HSTS)
[!] Server 版本: nginx/1.21.5 (2021-Dec, known CVEs)
[!] 支持 HTTP 与 HTTPS - 支持
```

图: nginx 版本过旧 + Swagger 未禁用

未授权访问安全测试

测试编号	VULN-015
风险名称	未授权访问安全测试
风险等级	高
功能要求	应用软件应不存在常见的未授权访问漏洞，如 Spring Boot Actuator 未授权访问漏洞，Spring Eureka 未授权访问漏洞，MongoDB 未授权访问漏洞，swagger 未授权访问漏洞，Hadoop 未授权访问漏洞等。
风险影响	存在敏感信息泄露风险
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	不符合
截图说明	Swagger-UI 未授权可访问：/server-api/webjars/swagger-ui/index.html 返回完整 Swagger 界面（200）；/server-api/v3/api-docs 返回 OpenAPI JSON（含内部服务器地址）；/server-api/v3/api-docs/swagger-config 返回 Swagger 配置。均无需认证即可访问。
修复建议	生产环境禁用 Swagger（springdoc.swagger-ui.enabled=false 或 springdoc.api-docs.enabled=false）；或对 /webjars/swagger-ui/ 和 /v3/api-docs 路径增加认证拦截。
备注	

```
##### (SQL/XSS/Swagger)

# SQL Injection (GET /system/user/list?userName=...)
normal 'admin' -> total=4, msg='####'
quote 'admin\'' -> total=0, msg='####' (no error)
bool 'admin\' or 1=1' -> total=0 (no extra data)
union 'union select' -> total=0 (no error)
comment 'admin\'--' -> total=0 (no error)
[+] ##### SQL 测试 (#####)

# XSS (GET /system/user/list?userName=<script>...)
payload: <script>alert(1)</script>
response: Content-Type: application/json, total=0
[+] API 返回 JSON, 返回 HTML 页面

# Swagger-UI (unauthenticated)
/server-api/webjars/swagger-ui/index.html -> 200 (HTML page)
/server-api/v3/api-docs -> 200 (OpenAPI JSON)
/server-api/v3/api-docs/swagger-config -> 200
[!] Swagger 无需认证即可访问
```

图：Swagger-UI 无需认证即可访问

敏感信息泄露安全测试

测试编号	VULN-016
风险名称	敏感信息泄露安全测试
风险等级	中
功能要求	应用软件应不存在下列敏感信息泄露风险 1、源代码泄露：公开暴露的源代码文件（如.php，.jsp，.py，.asp等）可能包含敏感信息，如数据库连接字符串、API 密钥、硬编码凭据等。 2、配置文件泄露：包含敏感配置信息的文件（如.env，config.php，web.config等）被公开，可能泄露数据库凭据、加密密钥、系统设置等。 3、备份文件泄露：未受保护的数据库、系统或网站备份文件可能包含大量敏感数据，如用户信息、交易记录、内部文档等。 4、未授权访问的管理界面：如后台管理面板、控制台等，攻击者可能通过默认或弱口令进入，直接操控系统。 5、默认示例文件泄露：如安装脚本、示例页面、测试数据等，它们可能提供有关系统架构、软件版本或配置的信息，也可能成为攻击入口。
风险影响	存在应用服务敏感信息泄露风险
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	不符合
截图说明	敏感信息泄露：1) Server: nginx/1.21.5 暴露精确中间件版本；2) /v3/api-docs 泄露内部服务器地址 http://10.124.10.249；3) 系统配置 API 暴露初始密码 sys.user.initPassword（结合越权任意用户可读）。
修复建议	配置 nginx server_tokens off 隐藏版本；禁用/保护 api-docs；初始密码不应存入可查询的配置表。
备注	

```

SQLMap (SQLMap/XSS/Swagger)

# SQL Injection (GET /system/user/list?userName=...)
normal 'admin'      -> total=4, msg='成功'
quote  'admin\'\'   -> total=0, msg='成功' (no error)
bool   'admin\' or 1=1' -> total=0 (no extra data)
union  'union select' -> total=0 (no error)
comment 'admin\'--'  -> total=0 (no error)
[+] 成功成功成功成功 SQL 注入 (成功)

# XSS (GET /system/user/list?userName=<script>...)
payload: <script>alert(1)</script>
response: Content-Type: application/json, total=0
[+] API 成功 JSON, 成功 HTML 成功

# Swagger-UI (unauthenticated)
/server-api/webjars/swagger-ui/index.html -> 200 (HTML page)
/server-api/v3/api-docs -> 200 (OpenAPI JSON)
/server-api/v3/api-docs/swagger-config -> 200
[!] Swagger 成功: 成功成功

```

图：多处敏感信息泄露

处理用时安全测试

测试编号	VULN-017
风险名称	处理用时安全测试
风险等级	中
功能要求	应用软件应不存在拒绝服务漏洞，如查询时间更改导致的拒绝服务漏洞、修改尺寸大小造成拒绝服务漏洞、退出登录处存在的拒绝服务漏洞等
风险影响	存在应用软件无法正常提供服务的风险，影响用户体验
测试依据	《OWASP Web Security Testing Guide v4.2》
测试结果	不符合
截图说明	对列表接口提交 GET /system/user/list?pageSize=99999 时，服务端一次性返回全部 432 条记录，未对分页大小设上限。在大数据量表（如 19768 条登录日志）上恶意请求超大 pageSize 可导致内存/数据库资源耗尽，存在资源耗尽型 DoS 风险。为保护可用性，未做高并发/大流量冲击测试。
修复建议	服务端强制限制分页 pageSize 最大值（如≤100），超限拒绝或截断；对敏感/大表查询增加限流、超时与结果集上限。
备注	仅验证分页无上限这一资源耗尽风险点，未做实际 DoS 冲击。

```

漏洞: 漏洞/漏洞/DoS/漏洞

# XXE (VULN-005)
POST /auth/login Content-Type: application/xml
-> "Content type 'application/xml' not supported" [+] 漏洞JSON, 漏洞XXE

# Deserialization (VULN-011)
Java漏洞 (AC ED 00 05) -> 'Content type not supported' [+] 漏洞
Fastjson @type 漏洞 -> 漏洞JSON漏洞, @type漏洞 [+] 漏洞Jackson, 漏洞

# SSRF (VULN-007) / 漏洞 (VULN-010)
common/download/url, common/proxy -> 404 [+] 漏洞漏洞
漏洞 ../../etc/passwd -> 404 [+] 漏洞漏洞

# LDAP (VULN-009)
sys.ldap.* 漏洞, 漏洞漏洞 -> 漏洞

# DoS (VULN-017)
GET /system/user/list?pageSize=99999 -> 漏洞漏洞432
[!] 漏洞漏洞, 漏洞漏洞漏洞

# 漏洞 (BUS-004)
pageNum=-1 & pageSize=abc -> code:200 '漏洞' (漏洞漏洞)
[!] 漏洞漏洞/漏洞

# 漏洞 (AUTH-002)
PUT /system/user/profile/updatePwd (漏洞) -> '漏洞'
[+] 漏洞漏洞

# 漏洞 (AUTH-004) / 漏洞 (AUTH-003)
sys.user.forceChangePwd=漏洞; 漏洞/OTP漏洞
[!] 漏洞漏洞; 漏洞漏洞

```

图: `pageSize=99999` 一次返回全量, 未限制